DevSecOps pipeline: final report

Oussama Koudhai · 4NIDS6, Esprit
Spring Boot student-management API
Project repository
Report built 2026-11-11 from revision `1298e55`.

First GitHub-hosted run on master

The pipeline passed on 11 November 2026 after PR #28 merged. SonarQube, Nexus, the image registry, the Compose stack and monitoring all ran on the disposable GitHub-hosted runner. Nmap acceptance passed, both Prometheus targets were UP, and all 30 sample API requests succeeded. The seven UI screenshots below come from this run. GitHub Actions run 43076300738 · Combined report artifact

The 5 November Azure run 42108525318 remains the historical evidence for delivery to an Azure VM. The Azure workflow is now manually triggered. The hosted workflow runs on pushes to `master` and pull requests targeting it.

Pipeline at a glance

#	Stage	Technique	Tool	Blocks the pipeline when	Report	Status
A. Commit and pre-build security (before Maven compiles anything)						
1	Threat modelling	STRIDE threat model, reviewed by a human before coding	documentation/THREAT-MODEL.md	The document must exist; CI preserves it with the run's reports	`precommit/THREAT-MODEL.md`	**Verified in a real run**
2	Pre-commit hooks	Local hooks replayed in CI: YAML/XML validity, merge markers, private-key headers, staged-secret scan	pre-commit, Gitleaks (staged snapshot)	Any hook failure stops the pipeline	`precommit/report.html`	**Verified in a real run**
3	Static application security testing	SAST with project rules for command execution, concatenated SQL and disabled TLS verification	Semgrep	Any finding fails (--error --strict)	`sast/report.html`	**Verified in a real run**
4	Secret scanning	Full Git history scan with redacted output	Gitleaks	Any new finding fails; one exact historical fingerprint is documented in SECURITY.md	`secrets/report.html`	**Verified in a real run**
5	Dependency analysis and SBOM	Software composition analysis of the source POM with a CycloneDX inventory	Trivy	HIGH/CRITICAL fails; empty or unversioned inventory is rejected	`dependencies/report.html`	**Verified in a real run**
6	Infrastructure-as-code policy	Terraform fmt/validate, policy scan, custom SSH-to-internet rule, workflow lint, Caddy config validation	Terraform, Checkov, actionlint	Any unexcepted failure; ten exclusions are documented in SECURITY.md	`iac/report.html`	**Verified in a real run**
7	Collect pre-build reports	Aggregate every scanner output into one readable index	scripts/render-security-reports.py	Runs even after a failed gate	`index.html`	**Verified in a real run**
B. Build, quality and artifact						
8	Compile, test and coverage	Unit and HTTP integration tests with coverage measurement	Maven, JUnit (Surefire), JaCoCo	Any failed test blocks the image build	`build/report.html`	**Verified in a real run**

#	Stage	Technique	Tool	Blocks the pipeline when	Report	Status
9	Code quality gate	Static analysis with a blocking quality gate	SonarQube Community Build	The pipeline waits for the gate and fails if it fails	`quality/report.html`	**Verified in a real run**
10	Artifact repository	Publish the tested JAR, then compare the stored checksum with the tested JAR	Sonatype Nexus	A different stored checksum fails the stage	`artifact/report.html`	**Verified in a real run**
11	Image build and vulnerability gate	Build a non-root image from the tested JAR and scan the final image. The parallel commit workflow also smoke-tests the image on ephemeral k3s.	Docker, Trivy, k3d	Any HIGH/CRITICAL finding fails, including unfixed ones	`image/report.html`	**Verified in a real run**
C. Delivery on the GitHub-hosted runner						
12	Image registry	Push the scanned image and deploy by immutable digest	Docker Distribution registry (runner loopback)	The digest must belong to the pushed image	`registry/report.html`	**Verified in a real run**
13	Deployment	Start the lab's Compose stack on the runner and verify the running image digest and database-backed API	Docker Compose, Spring Boot, MySQL	The running image must match the scanned digest and a database-backed API request must pass	`deploy/report.html`	**Verified in a real run**
D. Acceptance						
14	Network acceptance	Scan the runner's primary IPv4 address and loopback against a TCP allowlist	Nmap	Unexpected open, missing required or incomplete scans fail	`acceptance/report.html`	**Verified in a real run**
E. Production (after acceptance)						
15	Monitoring: Prometheus and Grafana	Verify scrape targets, sample real queries after light API traffic, list provisioned dashboards	Prometheus, Node Exporter, Grafana	API and runner exporter UP, Grafana database healthy, both dashboards provisioned	`monitoring/, prometheus/, grafana/ report.html`	**Verified in a real run**
16	Dependency updates and security alerts	Continuous dependency maintenance: weekly version-update PRs for five ecosystems and GitHub's vulnerability alerts, collected into a report on every push	Dependabot, GitHub REST API	Reported, not blocking: disabled alerts, HIGH/CRITICAL alerts and failing update PRs are highlighted for attention	`dependabot/report.html`	**Verified in a real run**
F. Notification						
17	Email notification	Status, per-stage results and the run link sent at the end of every master run	SMTP over STARTTLS	Runs even after failure or cancellation	`the email, and the job in the run graph`	**Partly verified**

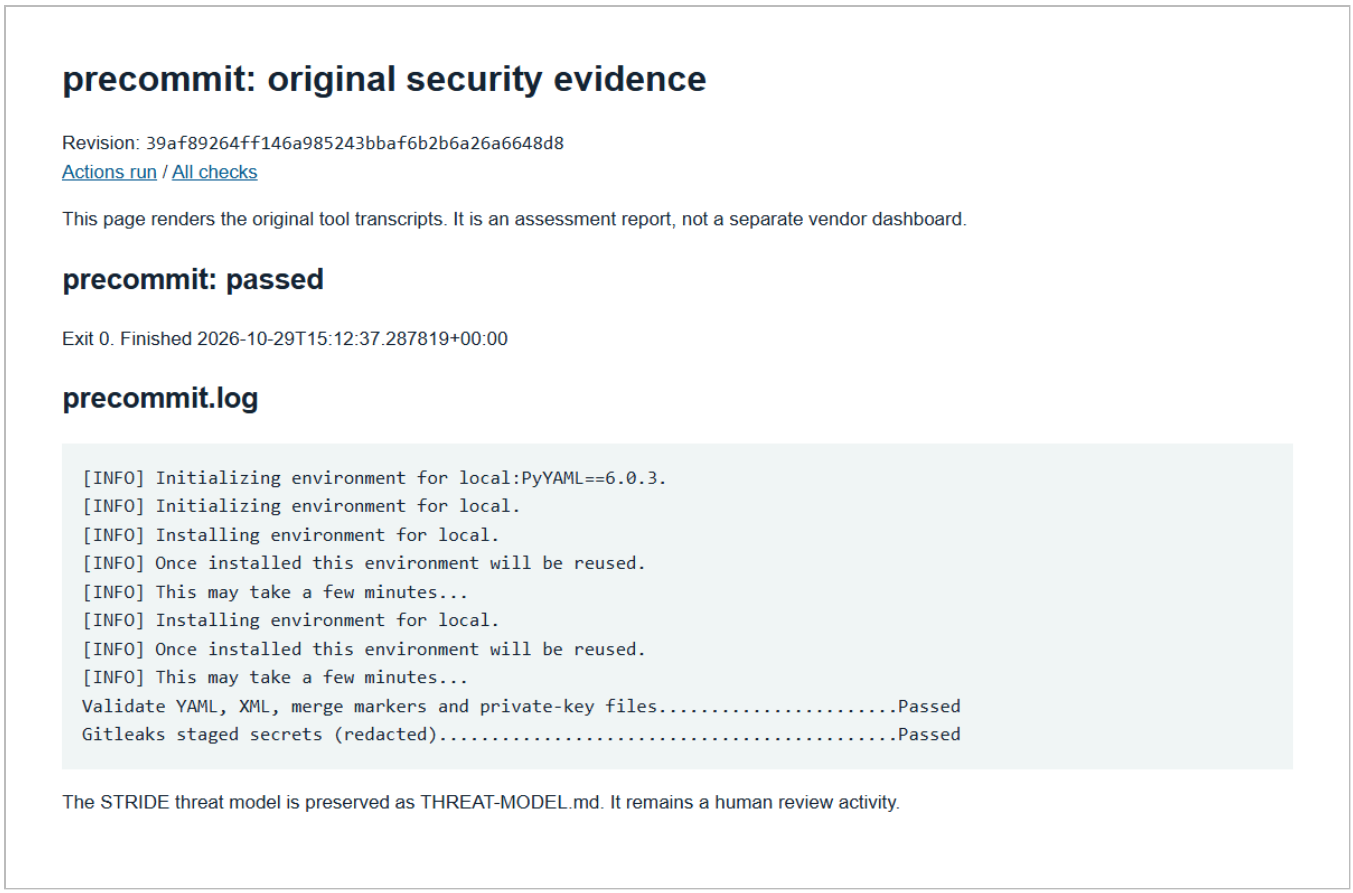
Stage by stage, with proof

A. Commit and pre-build security (before Maven compiles anything)

1. Threat modelling [Verified in a real run]

Technique: STRIDE threat model, reviewed by a human before coding
Tool: documentation/THREAT-MODEL.md
Blocks the pipeline when: The document must exist; CI preserves it with the run's reports
Report: `precommit/THREAT-MODEL.md`

Threat modelling is a human review: a green job proves the file is preserved, not that the analysis is complete.



precommit: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

precommit: passed

Exit 0. Finished 2026-10-29T15:12:37.287819+00:00

precommit.log

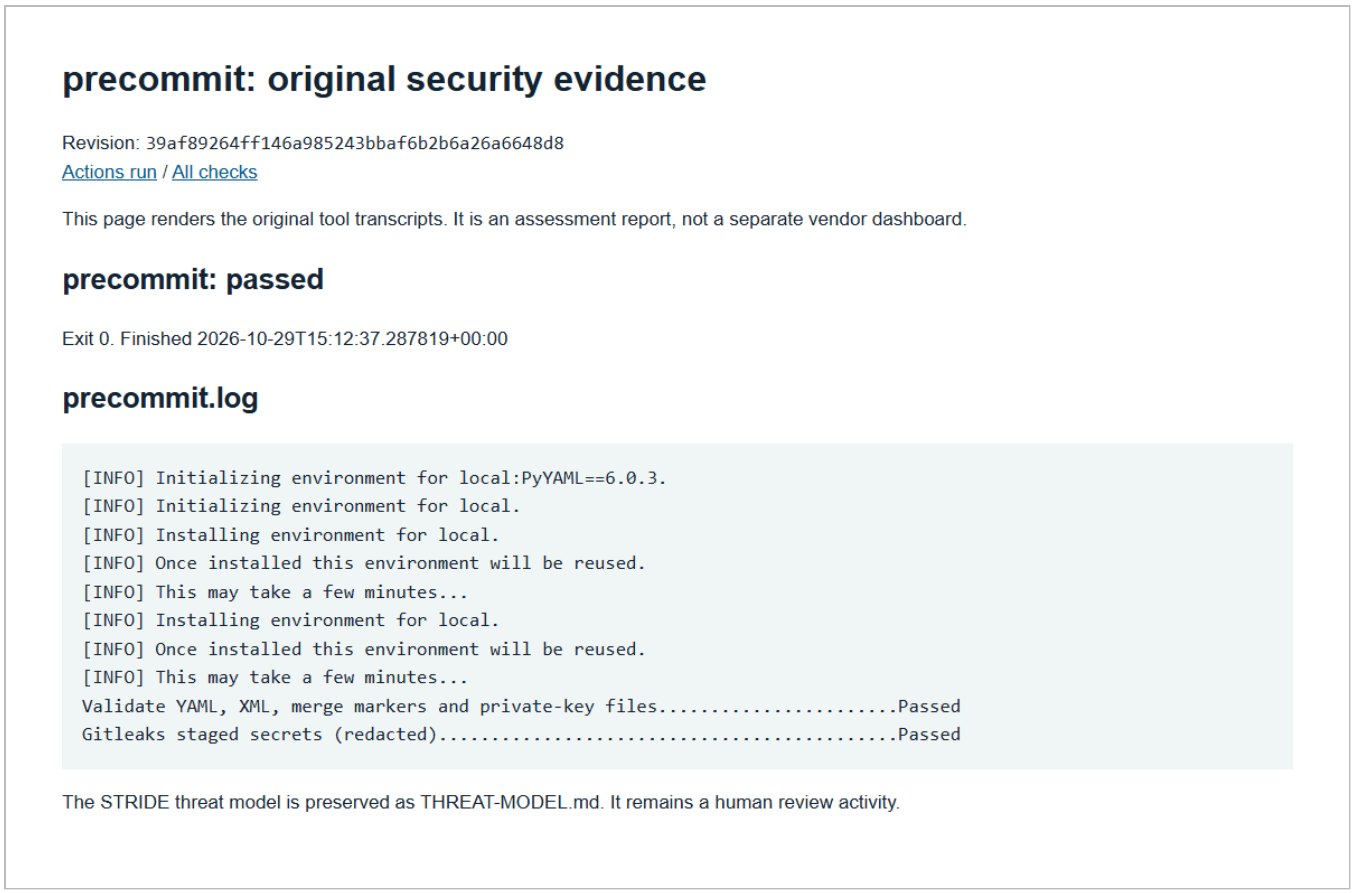
```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The STRIDE threat model is preserved as THREAT-MODEL.md. It remains a human review activity.

Pre-commit report page that preserves the threat model (run 40899036172, 29 Oct 2026)

2. Pre-commit hooks [Verified in a real run]

Technique: Local hooks replayed in CI: YAML/XML validity, merge markers, private-key headers, staged-secret scan
Tool: pre-commit, Gitleaks (staged snapshot)
Blocks the pipeline when: Any hook failure stops the pipeline
Report: `precommit/report.html`



precommit: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

precommit: passed

Exit 0. Finished 2026-10-29T15:12:37.287819+00:00

precommit.log

```
[INFO] Initializing environment for local:PyYAML==6.0.3.
[INFO] Initializing environment for local.
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
[INFO] Installing environment for local.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Validate YAML, XML, merge markers and private-key files.....................Passed
Gitleaks staged secrets (redacted)..........................................Passed
```

The STRIDE threat model is preserved as THREAT-MODEL.md. It remains a human review activity.

Hook transcript with Passed results (run 40899036172)

3. Static application security testing [Verified in a real run]

Technique: SAST with project rules for command execution, concatenated SQL and disabled TLS verification
Tool: Semgrep
Blocks the pipeline when: Any finding fails (--error --strict)
Report: `sast/report.html`

Deliberately narrow rule set, complemented by SonarQube.

sast: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

semgrep: passed

Exit 0. Finished 2026-10-29T15:13:05.819930+00:00

semgrep.log

```
┌──────────────┐
│ Scan Status │
└──────────────┘
  Scanning 19 files tracked by git with 3 Code rules:
  Scanning 19 files with 3 java rules.


┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 0 (0 blocking)
 • Rules run: 3
 • Targets scanned: 19
 • Parsed lines: ~100.0%
 • Scan was limited to files tracked by git
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 3 rules on 19 files: 0 findings.
If Semgrep missed a finding, please send us feedback to let us know!
See https://semgrep.dev/docs/reporting-false-negatives/
```

19 files scanned, 3 rules, 0 findings (run 40899036172)

4. Secret scanning [Verified in a real run]

Technique: Full Git history scan with redacted output
Tool: Gitleaks
Blocks the pipeline when: Any new finding fails; one exact historical fingerprint is documented in SECURITY.md
Report: `secrets/report.html`

secrets: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

gitleaks: passed

Exit 0. Finished 2026-10-29T15:12:47.119750+00:00

gitleaks.log

```
    ○
    │╲
    │ ○
    ○ ░
    ░    gitleaks

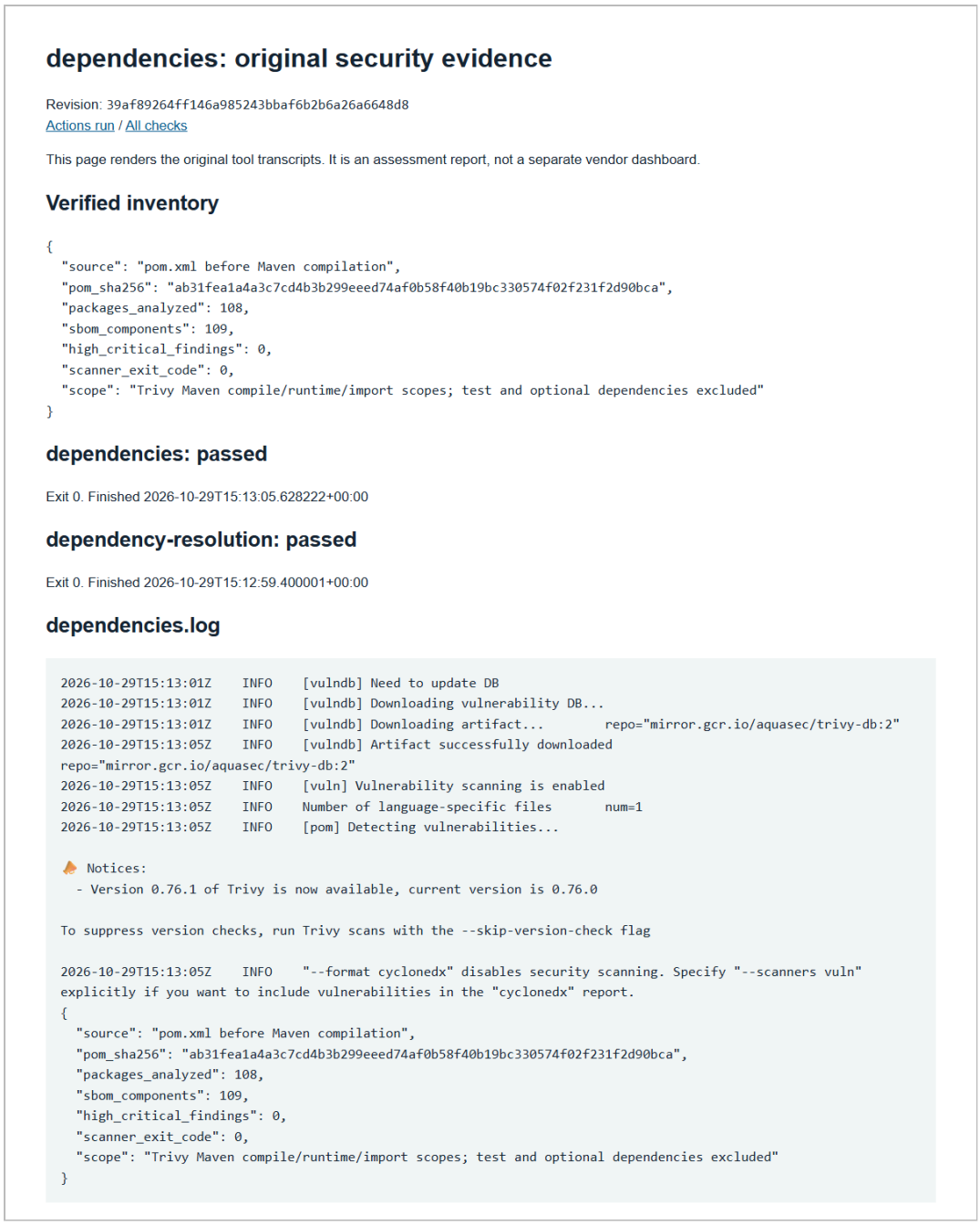
3:12PM INF 52 commits scanned.
3:12PM INF scanned ~535518 bytes (535.52 KB) in 386ms
3:12PM INF no leaks found
```

Gitleaks history scan passed (run 40899036172)

5. Dependency analysis and SBOM [Verified in a real run]

Technique: Software composition analysis of the source POM with a CycloneDX inventory
Tool: Trivy
Blocks the pipeline when: HIGH/CRITICAL fails; empty or unversioned inventory is rejected
Report: `dependencies/report.html`

An earlier green run had an empty inventory; the validator now rejects that.



dependencies: original security evidence

Revision: 39af89264ff146a985243bbaf6b2b6a26a6648d8
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

Verified inventory


```
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


dependencies: passed

Exit 0. Finished 2026-10-29T15:13:05.628222+00:00

dependency-resolution: passed

Exit 0. Finished 2026-10-29T15:12:59.400001+00:00

dependencies.log


```
2026-10-29T15:13:01Z    INFO    [vulndb] Need to update DB
2026-10-29T15:13:01Z    INFO    [vulndb] Downloading vulnerability DB...
2026-10-29T15:13:01Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-10-29T15:13:05Z    INFO    [vulndb] Artifact successfully downloaded
repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-10-29T15:13:05Z    INFO    [vuln] Vulnerability scanning is enabled
2026-10-29T15:13:05Z    INFO    Number of language-specific files       num=1
2026-10-29T15:13:05Z    INFO    [pom] Detecting vulnerabilities...

📣 Notices:
  - Version 0.76.1 of Trivy is now available, current version is 0.76.0

To suppress version checks, run Trivy scans with the --skip-version-check flag

2026-10-29T15:13:05Z    INFO    "--format cyclonedx" disables security scanning. Specify "--scanners vuln"
explicitly if you want to include vulnerabilities in the "cyclonedx" report.
{
  "source": "pom.xml before Maven compilation",
  "pom_sha256": "ab31fea1a4a3c7cd4b3b299eeed74af0b58f40b19bc330574f02f231f2d90bca",
  "packages_analyzed": 108,
  "sbom_components": 109,
  "high_critical_findings": 0,
  "scanner_exit_code": 0,
  "scope": "Trivy Maven compile/runtime/import scopes; test and optional dependencies excluded"
}
```


Verified inventory and SBOM summary (run 40899036172)

6. Infrastructure-as-code policy [Verified in a real run]

Technique: Terraform fmt/validate, policy scan, custom SSH-to-internet rule, workflow lint, Caddy config validation
Tool: Terraform, Checkov, actionlint
Blocks the pipeline when: Any unexcepted failure; ten exclusions are documented in SECURITY.md
Report: `iac/report.html`

iac: original security evidence

Revision: `39af89264ff146a985243bbaf6b2b6a26a6648d8`
Actions run / All checks

This page renders the original tool transcripts. It is an assessment report, not a separate vendor dashboard.

Policy counts

- checkov-course.json: 43 passed, 0 failed, 0 skipped
- checkov-default.json: 27 passed, 0 failed, 0 skipped

checkov-course: passed

Exit 0. Finished 2026-10-29T15:13:26.230894+00:00

checkov-default: passed

Exit 0. Finished 2026-10-29T15:13:23.519117+00:00

checkov-course.log

```
terraform scan results:

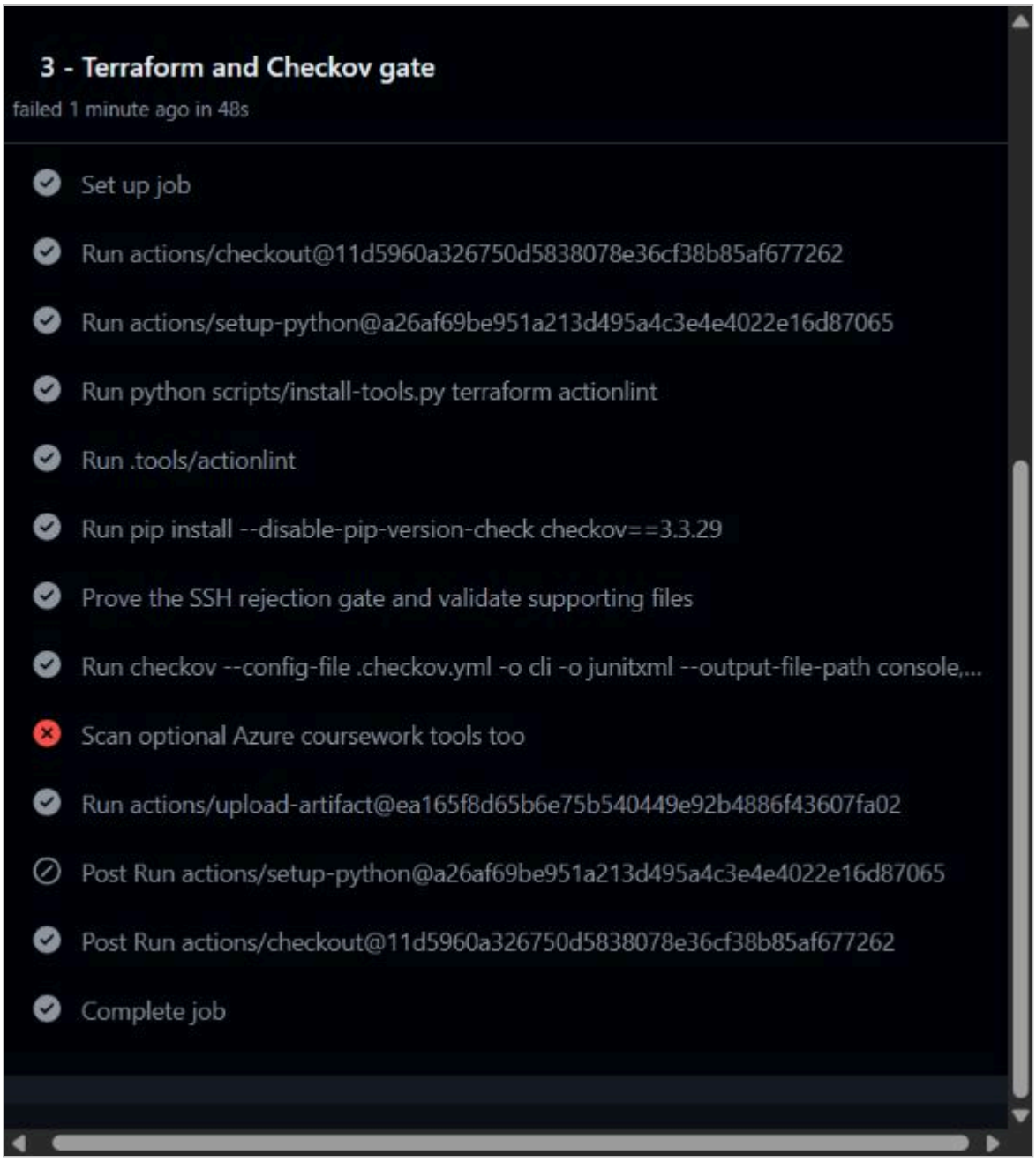
Passed checks: 43, Failed checks: 0, Skipped checks: 0
```

checkov-default.log

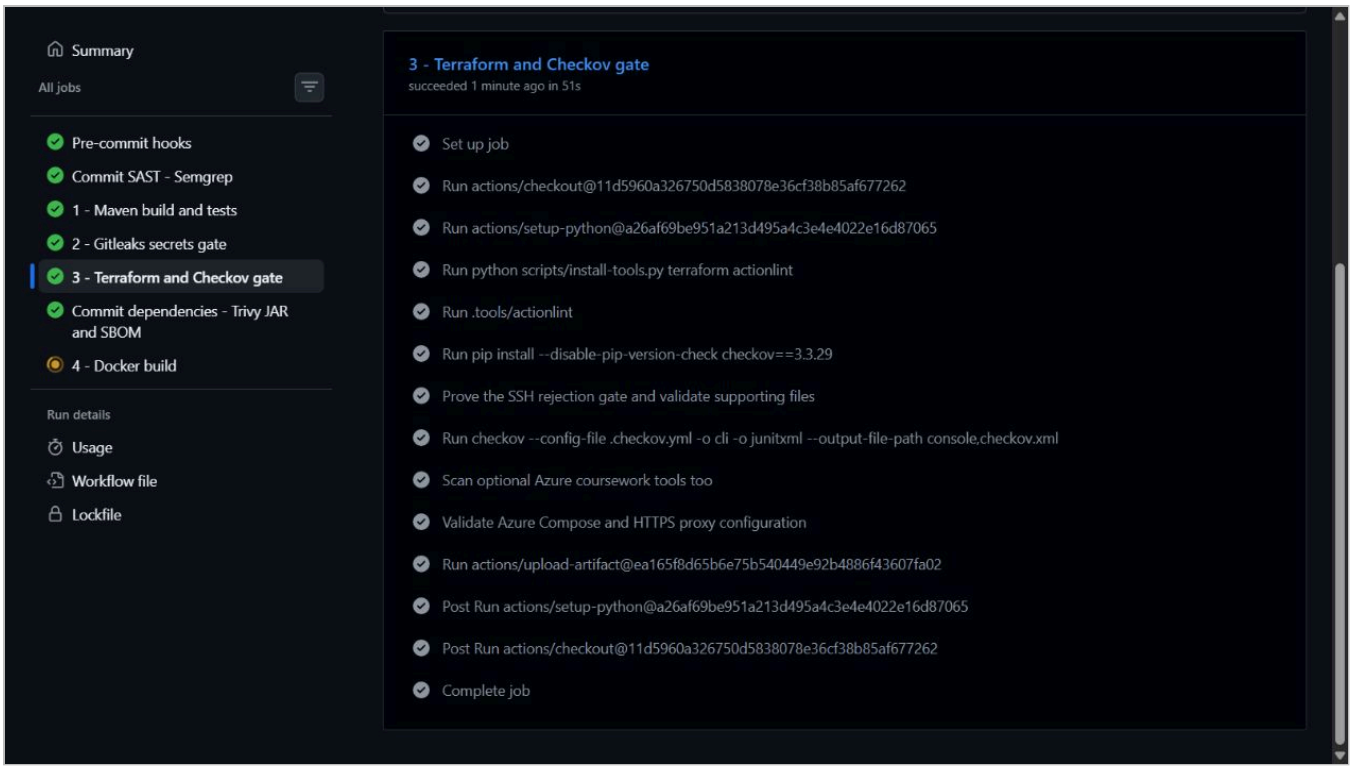
```
terraform scan results:

Passed checks: 27, Failed checks: 0, Skipped checks: 0
```

Checkov policy counts (run 40899036172)



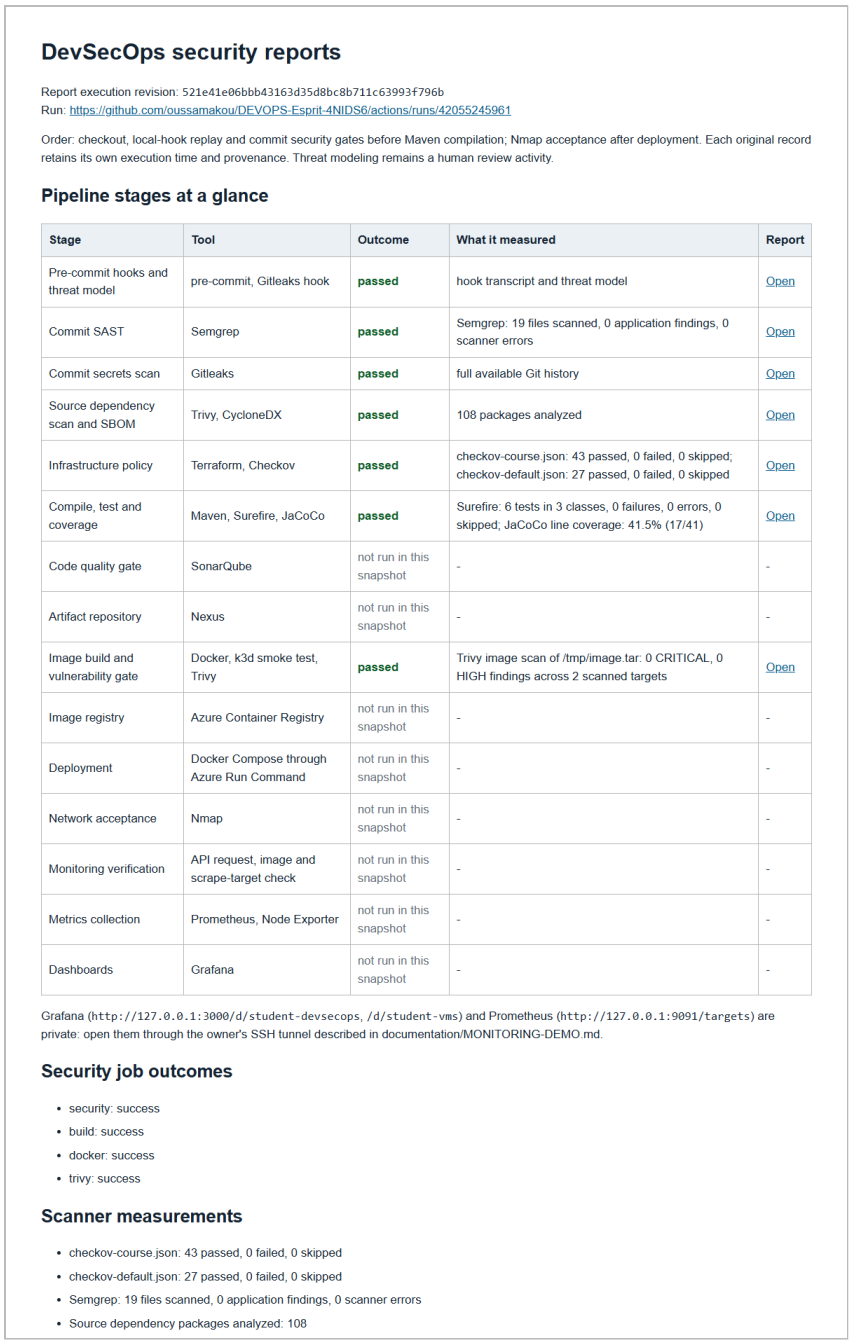
Real finding CKV_AZURE_160 (public HTTP port 80) failing the gate (run 39805052147)



Passing rescan after the port was closed (run 39805591559)

7. Collect pre-build reports [Verified in a real run]

Technique: Aggregate every scanner output into one readable index
Tool: scripts/render-security-reports.py
Blocks the pipeline when: Runs even after a failed gate
Report: `index.html`



DevSecOps security reports

Report execution revision: `521e41e06bbb43163d35d8bc8b711c63993f796b`
Run: https://github.com/oussamakou/DEVOPS-Esprit-4NIDS6/actions/runs/42055245961

Order: checkout, local-hook replay and commit security gates before Maven compilation; Nmap acceptance after deployment. Each original record retains its own execution time and provenance. Threat modeling remains a human review activity.

Pipeline stages at a glance

Stage	Tool	Outcome	What it measured	Report
Pre-commit hooks and threat model	pre-commit, Gitleaks hook	**passed**	hook transcript and threat model	Open
Commit SAST	Semgrep	**passed**	Semgrep: 19 files scanned, 0 application findings, 0 scanner errors	Open
Commit secrets scan	Gitleaks	**passed**	full available Git history	Open
Source dependency scan and SBOM	Trivy, CycloneDX	**passed**	108 packages analyzed	Open
Infrastructure policy	Terraform, Checkov	**passed**	checkov-course.json: 43 passed, 0 failed, 0 skipped; checkov-default.json: 27 passed, 0 failed, 0 skipped	Open
Compile, test and coverage	Maven, Surefire, JaCoCo	**passed**	Surefire: 6 tests in 3 classes, 0 failures, 0 errors, 0 skipped; JaCoCo line coverage: 41.5% (17/41)	Open
Code quality gate	SonarQube	not run in this snapshot	-	-
Artifact repository	Nexus	not run in this snapshot	-	-
Image build and vulnerability gate	Docker, k3d smoke test, Trivy	**passed**	Trivy image scan of /tmp/image.tar: 0 CRITICAL, 0 HIGH findings across 2 scanned targets	Open
Image registry	Azure Container Registry	not run in this snapshot	-	-
Deployment	Docker Compose through Azure Run Command	not run in this snapshot	-	-
Network acceptance	Nmap	not run in this snapshot	-	-
Monitoring verification	API request, image and scrape-target check	not run in this snapshot	-	-
Metrics collection	Prometheus, Node Exporter	not run in this snapshot	-	-
Dashboards	Grafana	not run in this snapshot	-	-

Grafana (`http://127.0.0.1:3000/d/student-devsecops`, `/d/student-vms`) and Prometheus (`http://127.0.0.1:9091/targets`) are private: open them through the owner's SSH tunnel described in documentation/MONITORING-DEMO.md.

Security job outcomes

- security: success
- build: success
- docker: success
- trivy: success

Scanner measurements

- checkov-course.json: 43 passed, 0 failed, 0 skipped
- checkov-default.json: 27 passed, 0 failed, 0 skipped
- Semgrep: 19 files scanned, 0 application findings, 0 scanner errors
- Source dependency packages analyzed: 108

Combined index generated by CI (run 42055245961, pull request 25)

B. Build, quality and artifact

8. Compile, test and coverage [Verified in a real run]

Technique: Unit and HTTP integration tests with coverage measurement
Tool: Maven, JUnit (Surefire), JaCoCo
Blocks the pipeline when: Any failed test blocks the image build
Report: `build/report.html`

6 tests, 41.5% line coverage in the CI run shown.



Compile, test and coverage: original evidence

Tool: Maven, Surefire, JaCoCo
Revision: 521e41e06bbb43163d35d8bc8b711c63993f796b
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Surefire: 6 tests in 3 classes, 0 failures, 0 errors, 0 skipped
- JaCoCo line coverage: 41.5% (17/41)

maven: passed

Exit 0. Started 2026-11-05T15:29:57.804310+00:00; finished 2026-11-05T15:30:26.168951+00:00

maven.log

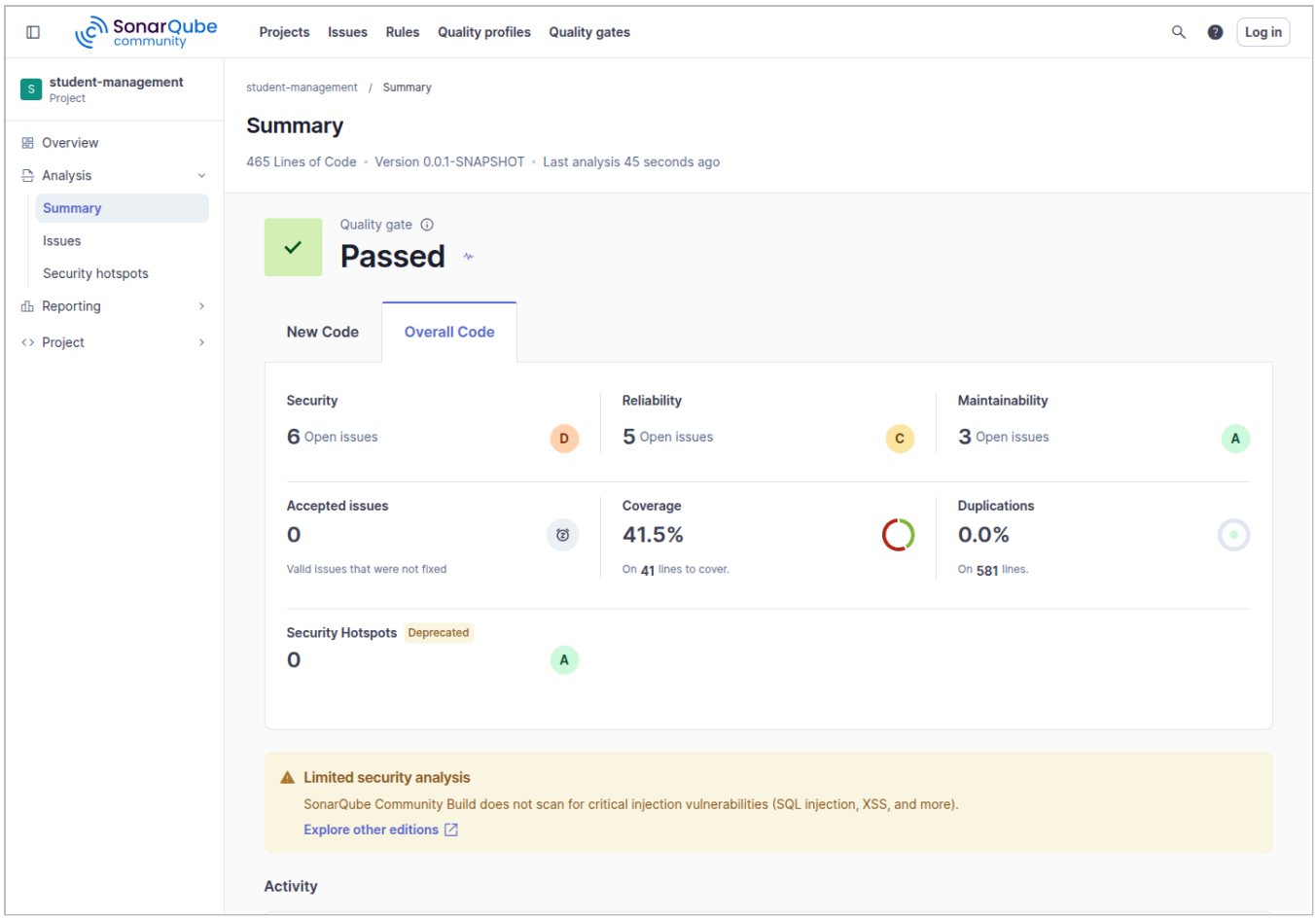
```
[INFO] Scanning for projects...
[INFO]
[INFO] --------------------< tn.esprit:student-management >--------------------
[INFO] Building student-management 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ jar ]---------------------------------
[INFO]
[INFO] --- jacoco:0.8.11:prepare-agent (prepare-agent) @ student-management ---
[INFO] argLine set to -javaagent:/home/runner/.m2/repository/org/jacoco/org.jacoco.agent/0.8.11/org.jacoco.agent-
0.8.11-runtime.jar=destfile=/home/runner/work/DEVOPS-Esprit-4NIDS6/DEVOPS-Esprit-4NIDS6/target/jacoco.exec
[INFO]
[INFO] --- resources:3.5.0:resources (default-resources) @ student-management ---
[INFO] Copying 1 resource from src/main/resources to target/classes
[INFO] Copying 0 resource from src/main/resources to target/classes
[INFO]
[INFO] --- compiler:3.15.0:compile (default-compile) @ student-management ---
[INFO] Recompiling the module because of changed source code.
[INFO] Compiling 19 source files with javac [debug parameters release 17] to target/classes
[INFO]
[INFO] --- resources:3.5.0:testResources (default-testResources) @ student-management ---
[INFO] Copying 1 resource from src/test/resources to target/test-classes
[INFO]
[INFO] --- compiler:3.15.0:testCompile (default-testCompile) @ student-management ---
[INFO] Recompiling the module because of changed dependency.
[INFO] Compiling 3 source files with javac [debug parameters release 17] to target/test-classes
[INFO]
[INFO] --- surefire:3.5.6:test (default-test) @ student-management ---
[INFO] Using auto detected provider org.apache.maven.surefire.junitplatform.JUnitPlatformProvider
[INFO]
[INFO] -------------------------------------------------------
[INFO]  T E S T S
[INFO] -------------------------------------------------------
[INFO] Running tn.esprit.studentmanagement.StudentManagementApplicationTests
15:30:10.743 [main] INFO org.springframework.test.context.support.AnnotationConfigContextLoaderUtils -- Could not
detect default configuration classes for test class
[tn.esprit.studentmanagement.StudentManagementApplicationTests]: StudentManagementApplicationTests does not
declare any static, non-private, non-final, nested classes annotated with @Configuration.
15:30:10.960 [main] INFO org.springframework.boot.test.context.SpringBootTestContextBootstrapper -- Found
@SpringBootConfiguration tn.esprit.studentmanagement.StudentManagementApplication for test class
tn.esprit.studentmanagement.StudentManagementApplicationTests
15:30:11.227 [main] INFO org.springframework.test.context.support.AnnotationConfigContextLoaderUtils -- Could not
detect default configuration classes for test class
[tn.esprit.studentmanagement.StudentManagementApplicationTests]: StudentManagementApplicationTests does not
declare any static, non-private, non-final, nested classes annotated with @Configuration.
```

Maven stage page: log, test counts and coverage (run 42055245961)

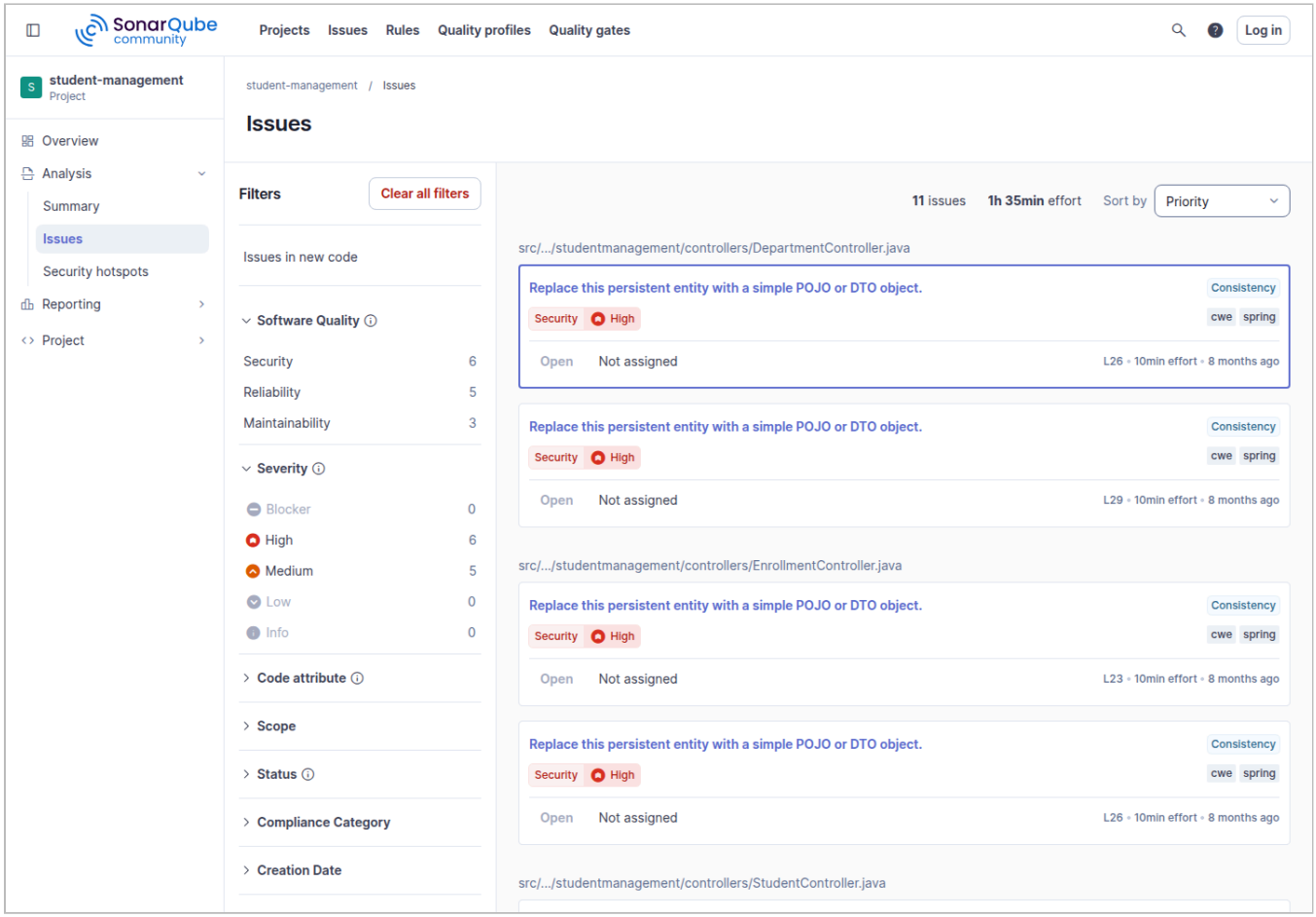
9. Code quality gate [Verified in a real run]

Technique: Static analysis with a blocking quality gate
Tool: SonarQube Community Build
Blocks the pipeline when: The pipeline waits for the gate and fails if it fails
Report: `quality/report.html`

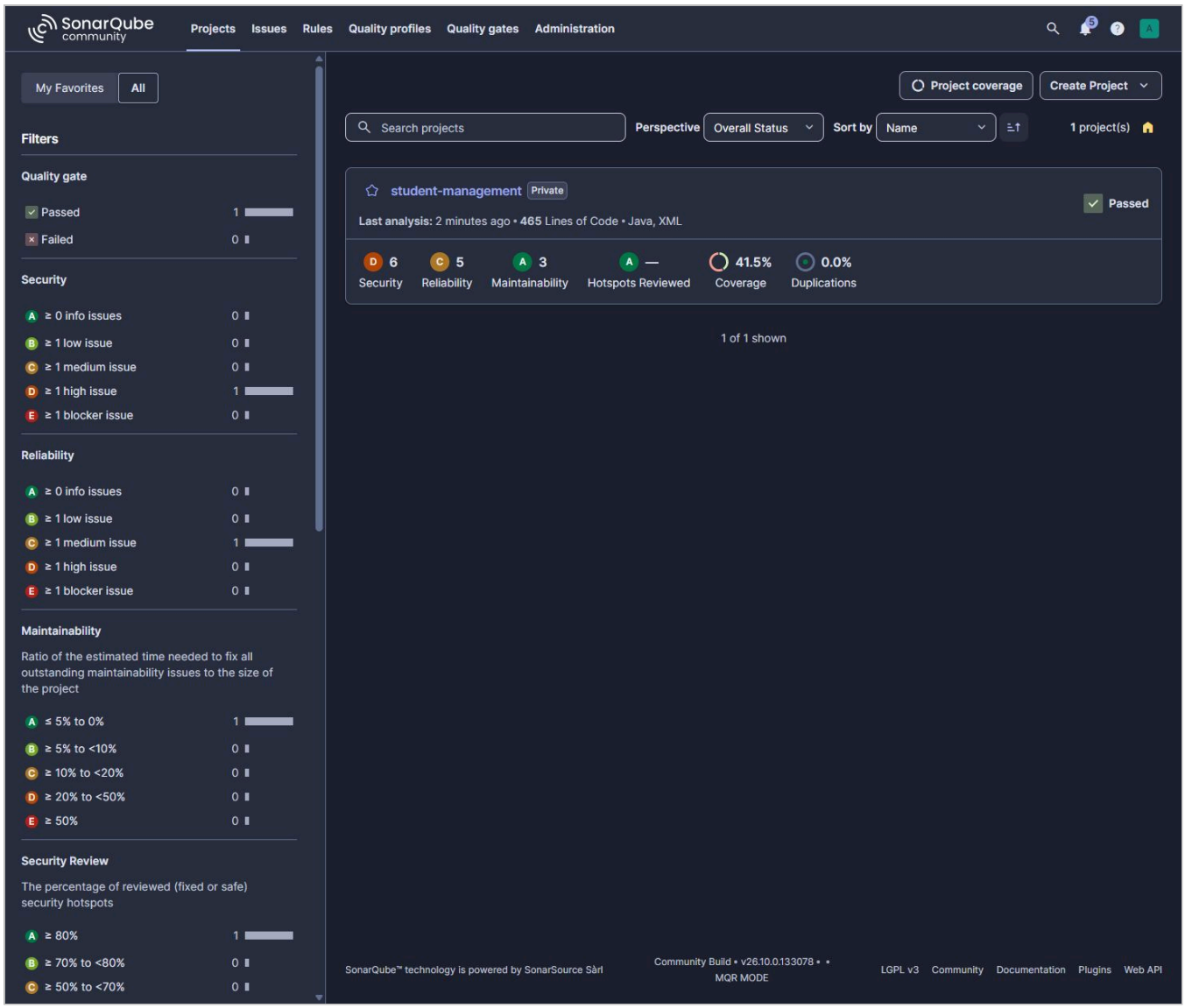
The blocking gate passed on the GitHub-hosted runner. The earlier Azure baseline recorded 11 issues, including six HIGH entity-binding findings.



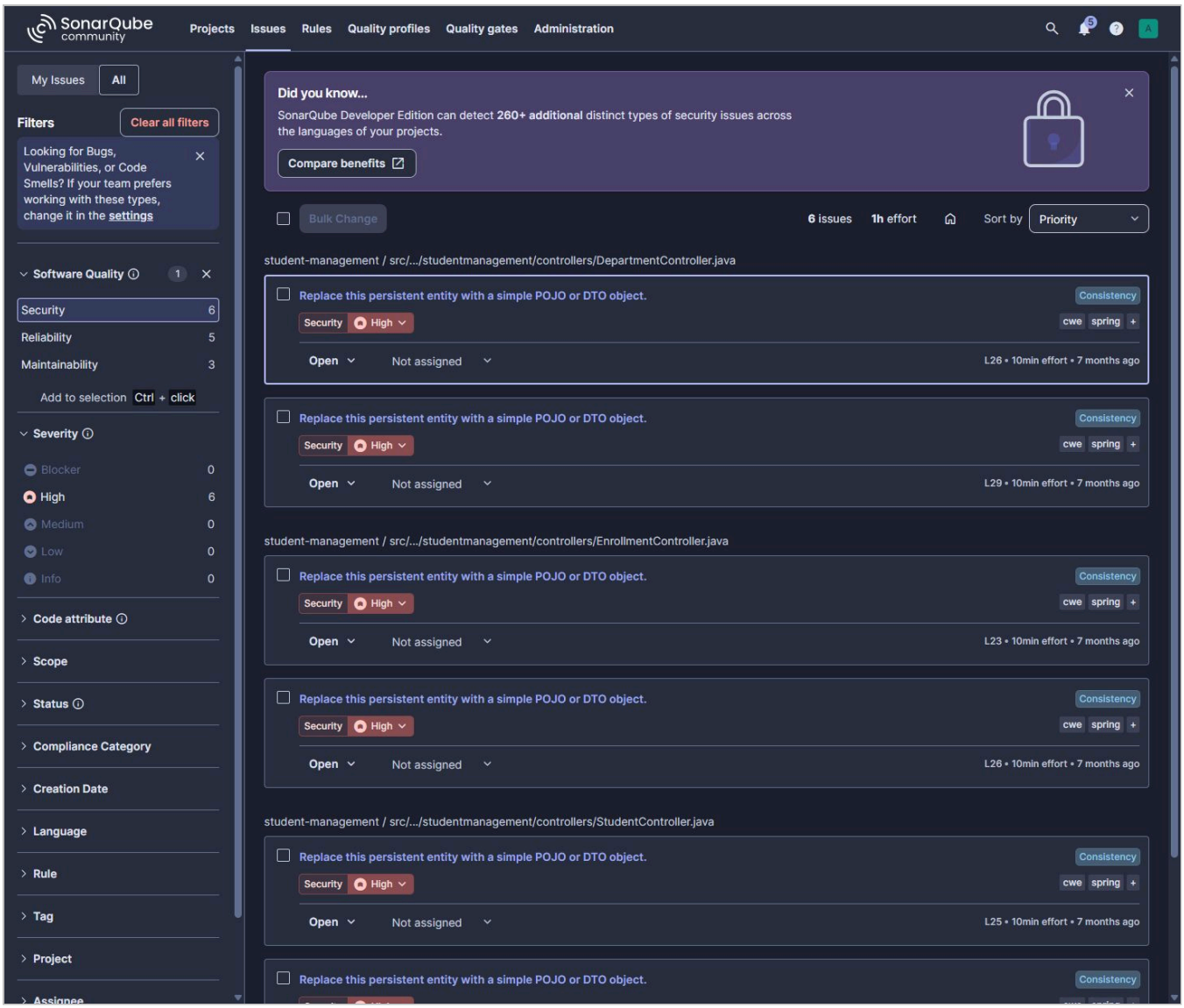
SonarQube project dashboard on the hosted runner (run 43076300738)



SonarQube issue list for the same analysis (run 43076300738)



First baseline: 41.5% coverage and 11 issues (run 39883066388)

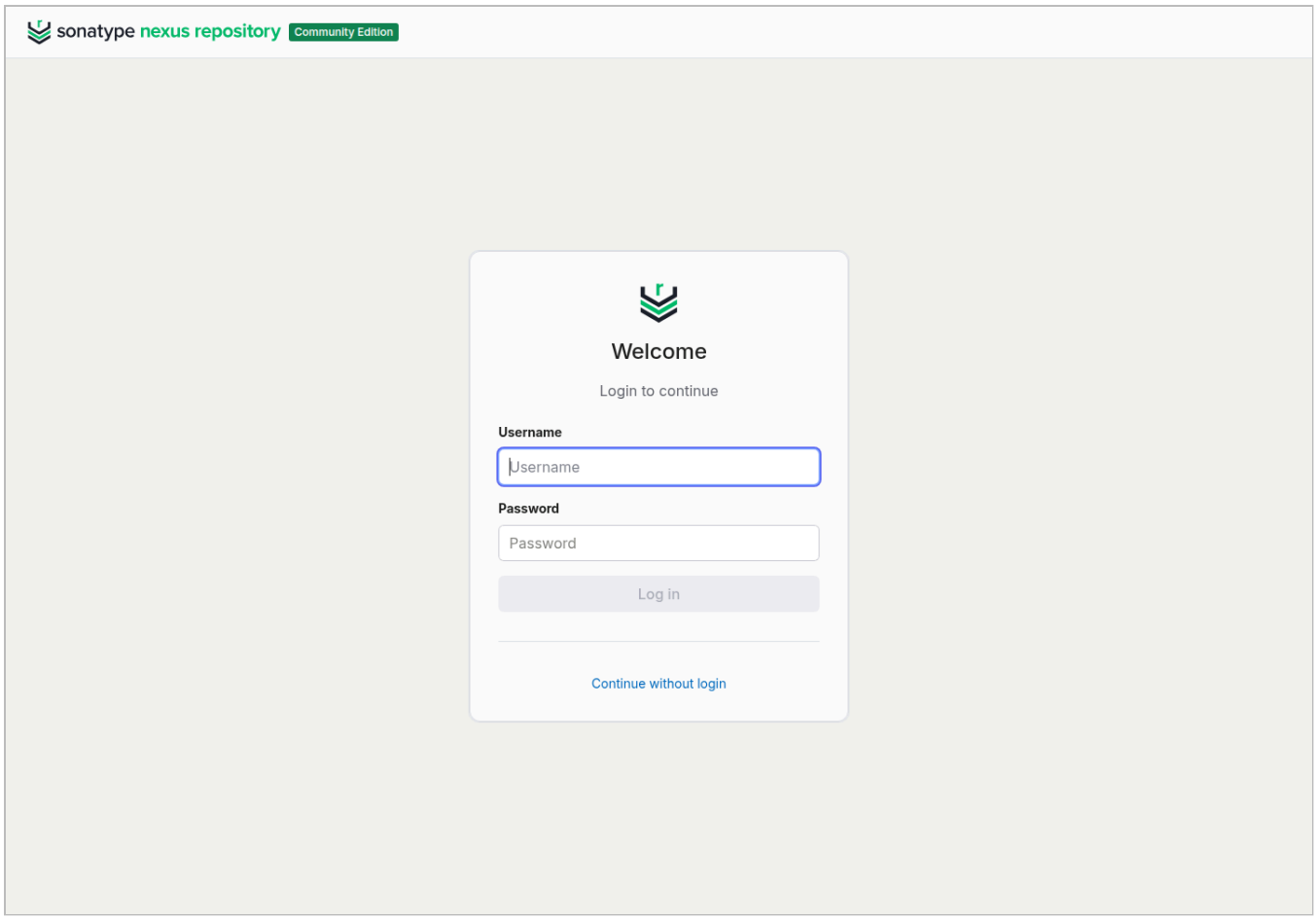


Six HIGH java:S4684 findings in the controllers from the earlier Azure baseline

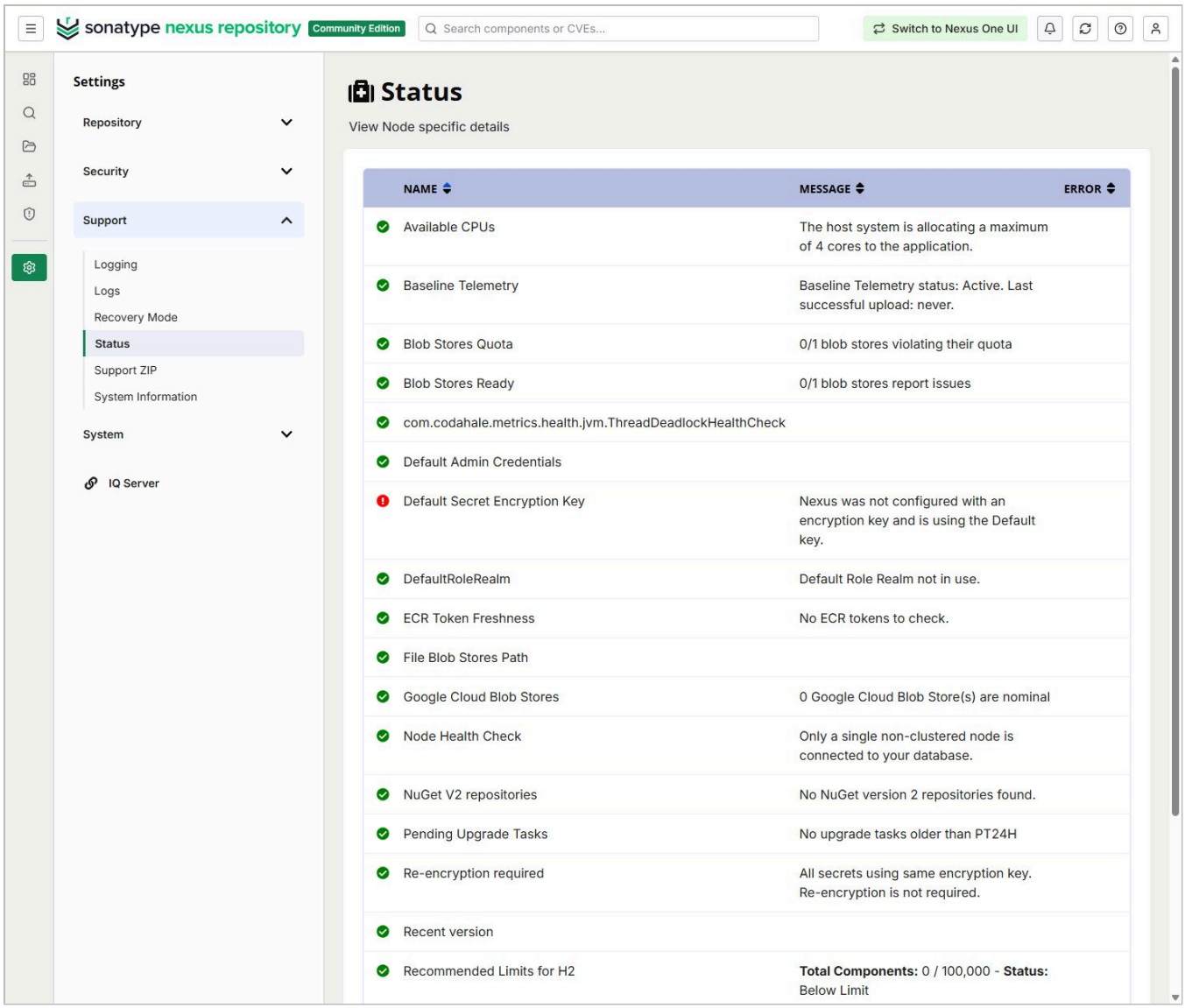
10. Artifact repository [Verified in a real run]

Technique: Publish the tested JAR, then compare the stored checksum with the tested JAR
Tool: Sonatype Nexus
Blocks the pipeline when: A different stored checksum fails the stage
Report: `artifact/report.html`

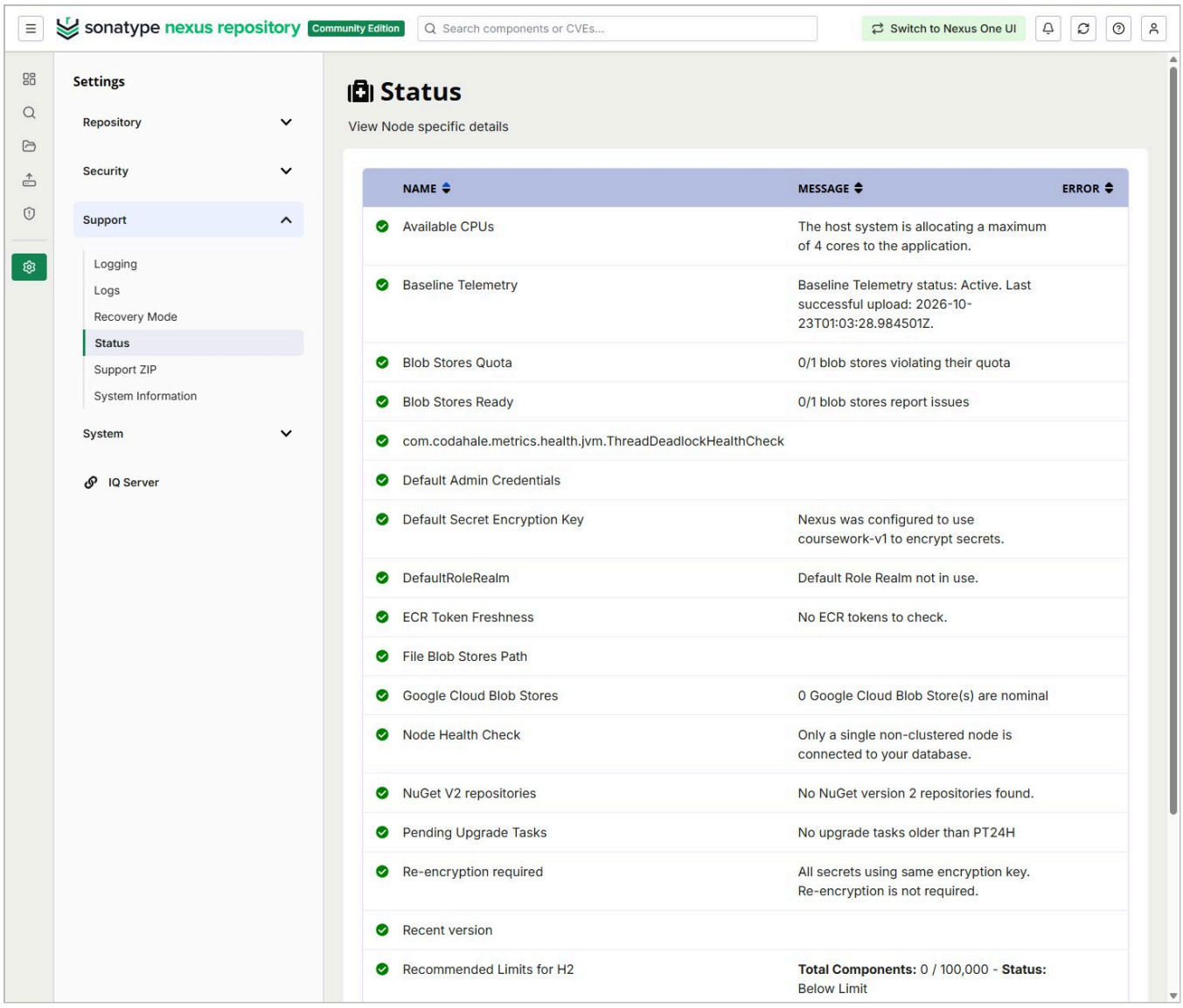
The hosted run's artifact report records matching SHA-1 checksums for the published snapshot and the tested JAR. The screenshot captured Nexus's sign-in screen when the runner opened the snapshot browser.



Nexus sign-in screen captured while opening the snapshot browser (run 43076300738)



Earlier real finding: Nexus used the default encryption key



After remediation with a private key

11. Image build and vulnerability gate [Verified in a real run]

Technique: Build a non-root image from the tested JAR and scan the final image. The parallel commit workflow also smoke-tests the image on ephemeral k3s.
Tool: Docker, Trivy, k3d
Blocks the pipeline when: Any HIGH/CRITICAL finding fails, including unfixed ones
Report: `image/report.html`

An earlier run was blocked by 11 HIGH/CRITICAL findings; see SECURITY-GATE-CASE-STUDY.md.

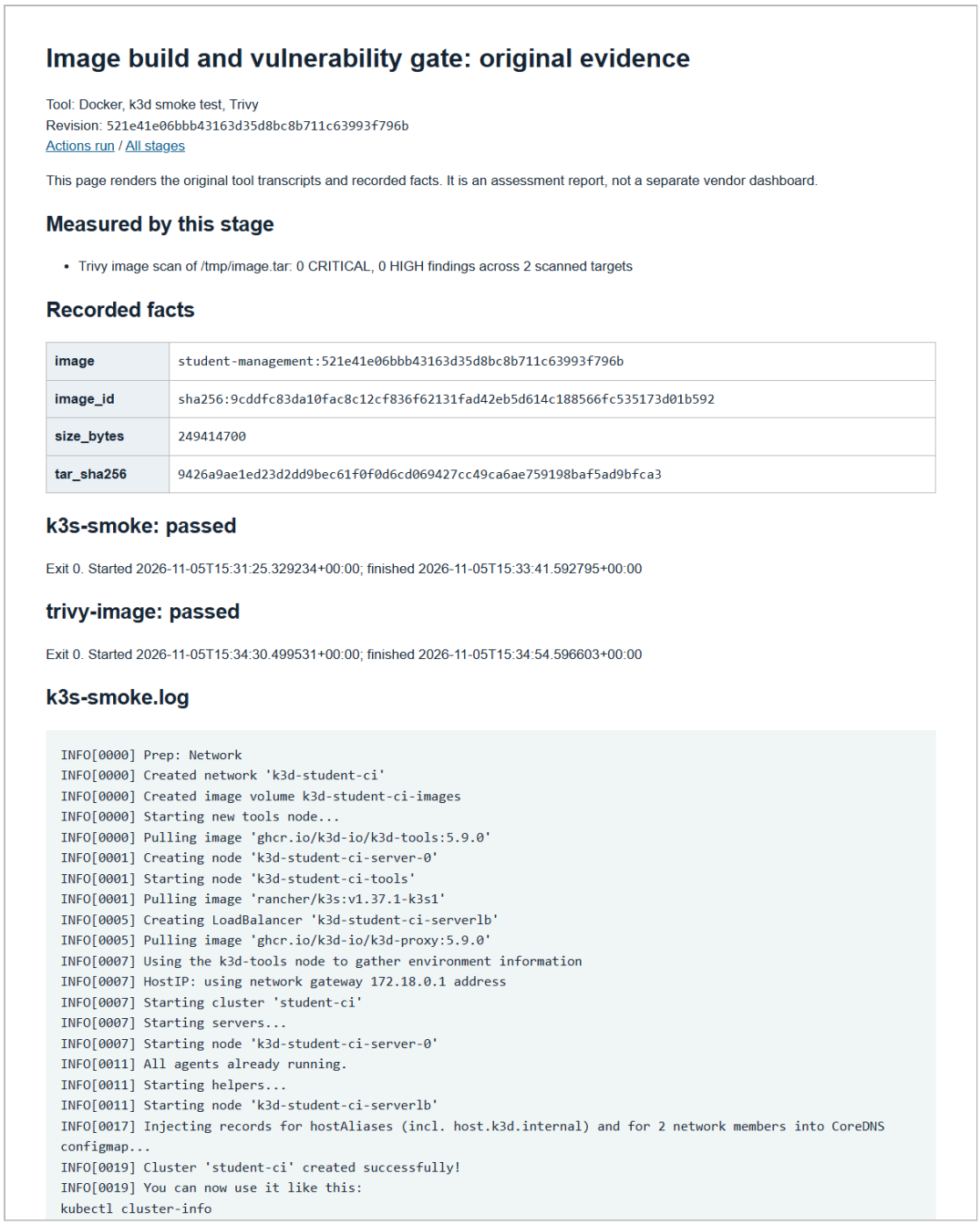


Image build and vulnerability gate: original evidence

Tool: Docker, k3d smoke test, Trivy
Revision: `521e41e06bbb43163d35d8bc8b711c63993f796b`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- Trivy image scan of /tmp/image.tar: 0 CRITICAL, 0 HIGH findings across 2 scanned targets

Recorded facts

image	`student-management:521e41e06bbb43163d35d8bc8b711c63993f796b`
image_id	`sha256:9cddfc83da10fac8c12cf836f62131fad42eb5d614c188566fc535173d01b592`
size_bytes	`249414700`
tar_sha256	`9426a9ae1ed23d2dd9bec61f0f0d6cd069427cc49ca6ae759198baf5ad9bfca3`

k3s-smoke: passed

Exit 0. Started 2026-11-05T15:31:25.329234+00:00; finished 2026-11-05T15:33:41.592795+00:00

trivy-image: passed

Exit 0. Started 2026-11-05T15:34:30.499531+00:00; finished 2026-11-05T15:34:54.596603+00:00

k3s-smoke.log

```
INFO[0000] Prep: Network
INFO[0000] Created network 'k3d-student-ci'
INFO[0000] Created image volume k3d-student-ci-images
INFO[0000] Starting new tools node...
INFO[0000] Pulling image 'ghcr.io/k3d-io/k3d-tools:5.9.0'
INFO[0001] Creating node 'k3d-student-ci-server-0'
INFO[0001] Starting node 'k3d-student-ci-tools'
INFO[0001] Pulling image 'rancher/k3s:v1.37.1-k3s1'
INFO[0005] Creating LoadBalancer 'k3d-student-ci-serverlb'
INFO[0005] Pulling image 'ghcr.io/k3d-io/k3d-proxy:5.9.0'
INFO[0007] Using the k3d-tools node to gather environment information
INFO[0007] HostIP: using network gateway 172.18.0.1 address
INFO[0007] Starting cluster 'student-ci'
INFO[0007] Starting servers...
INFO[0007] Starting node 'k3d-student-ci-server-0'
INFO[0011] All agents already running.
INFO[0011] Starting helpers...
INFO[0011] Starting node 'k3d-student-ci-serverlb'
INFO[0017] Injecting records for hostAliases (incl. host.k3d.internal) and for 2 network members into CoreDNS
configmap...
INFO[0019] Cluster 'student-ci' created successfully!
INFO[0019] You can now use it like this:
kubectl cluster-info
```

Image stage page: build facts, k3s smoke test and Trivy result, 0 HIGH/CRITICAL (run 42055245961)

C. Delivery on the GitHub-hosted runner

12. Image registry [Verified in a real run]

Technique: Push the scanned image and deploy by immutable digest
Tool: Docker Distribution registry (runner loopback)
Blocks the pipeline when: The digest must belong to the pushed image
Report: `registry/report.html`

The current run publishes to localhost:5000. Its report records the push log and digest. The screenshot below records the same technique on the earlier Azure registry.

Image registry: original evidence

Tool: Azure Container Registry
Revision: `db36f8379df2e0c6c38f8a2b7561df5e2b69418e`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- image: studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c

Recorded facts

registry	`studentcourse323d3b9d04d2.azurecr.io`
tag	`db36f8379df2e0c6c38f8a2b7561df5e2b69418e`
image	`studentcourse323d3b9d04d2.azurecr.io/student-management@sha256:a70de5456189a6ce0cef73b9ea9b28988c079bdb8a184ae8bfab4314e71e5d1c`

acr-push: passed

Exit 0. Started 2026-11-05T21:03:51.174725+00:00; finished 2026-11-05T21:04:02.006296+00:00

acr-push.log

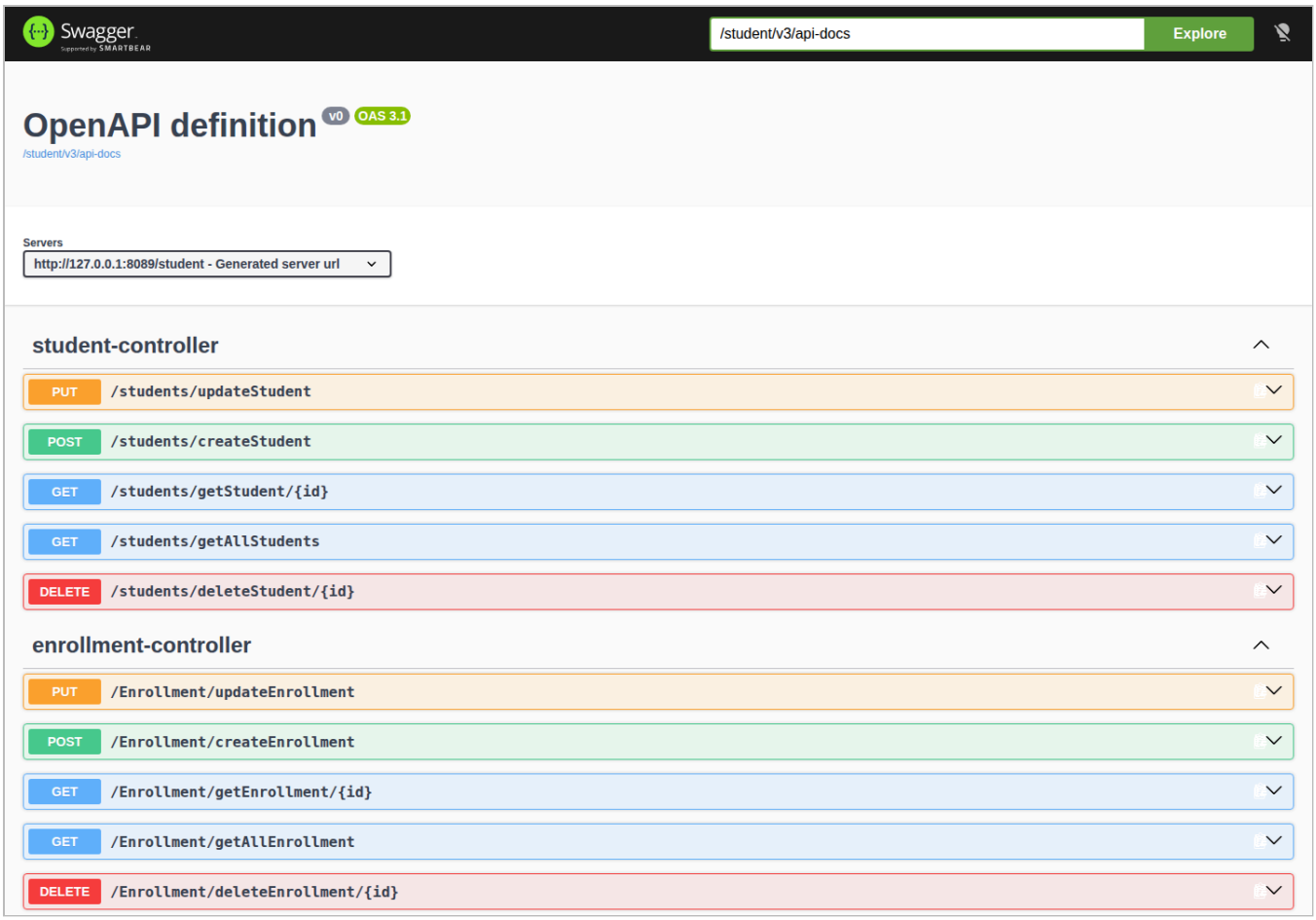
```
The push refers to repository [studentcourse323d3b9d04d2.azurecr.io/student-management]
bab38130ad99: Preparing
6c444736d45f: Preparing
11a649abf36e: Preparing
f0f3c4e2e1e0: Preparing
fcba58aaefa4: Preparing
b7a888f89d2b: Preparing
1c181ab443b7: Preparing
75c137aedfb2: Preparing
b7a888f89d2b: Waiting
1c181ab443b7: Waiting
75c137aedfb2: Waiting
6c444736d45f: Pushed
f0f3c4e2e1e0: Pushed
fcba58aaefa4: Pushed
11a649abf36e: Pushed
75c137aedfb2: Layer already exists
1c181ab443b7: Pushed
bab38130ad99: Pushed
```

Historical Azure registry push and immutable digest (run 42108525318)

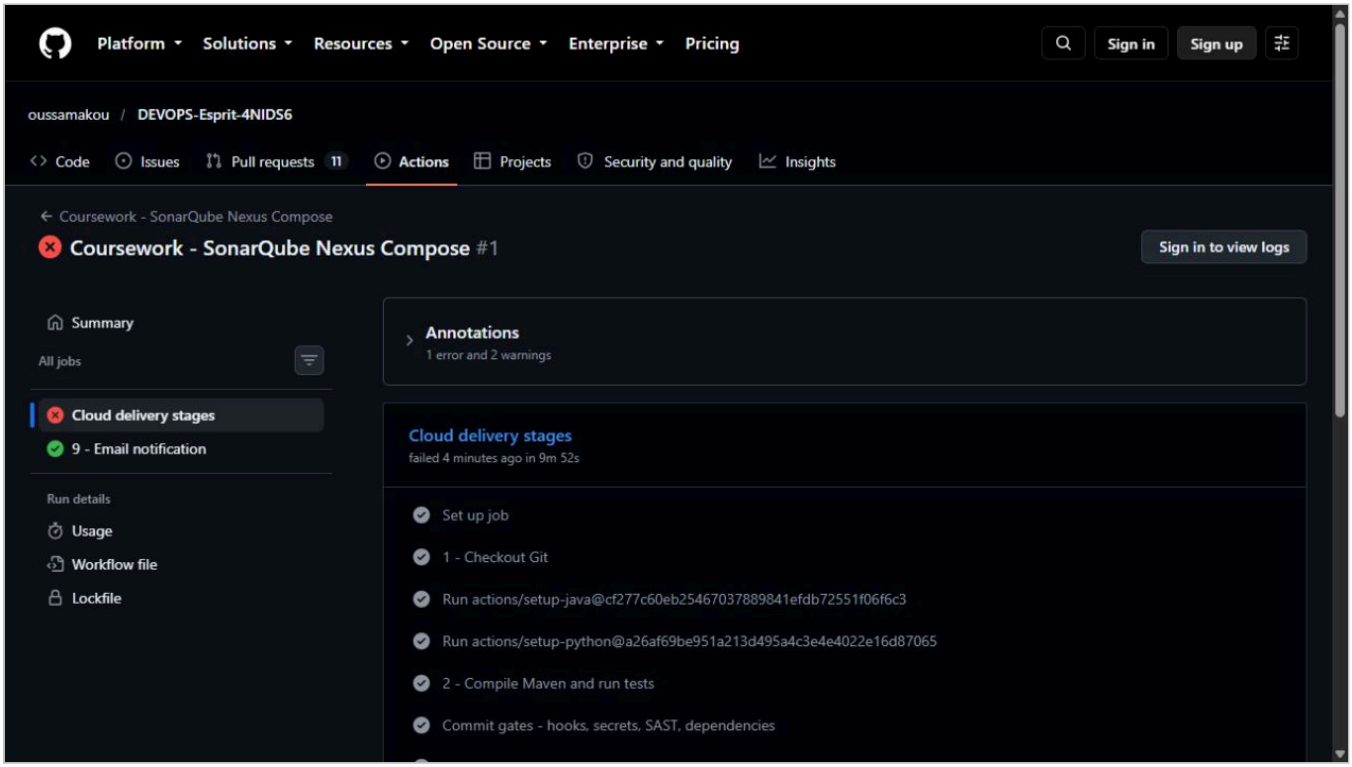
13. Deployment [Verified in a real run]

Technique: Start the lab's Compose stack on the runner and verify the running image digest and database-backed API
Tool: Docker Compose, Spring Boot, MySQL
Blocks the pipeline when: The running image must match the scanned digest and a database-backed API request must pass
Report: `deploy/report.html`

The Compose stack runs for the duration of the workflow. The current run recorded DEPLOY_SUCCEEDED and verified a database-backed API response.



Swagger UI for the API deployed on the runner (run 43076300738)



Historical Azure Compose startup failure, repaired before the later Azure run (run 39883066388)

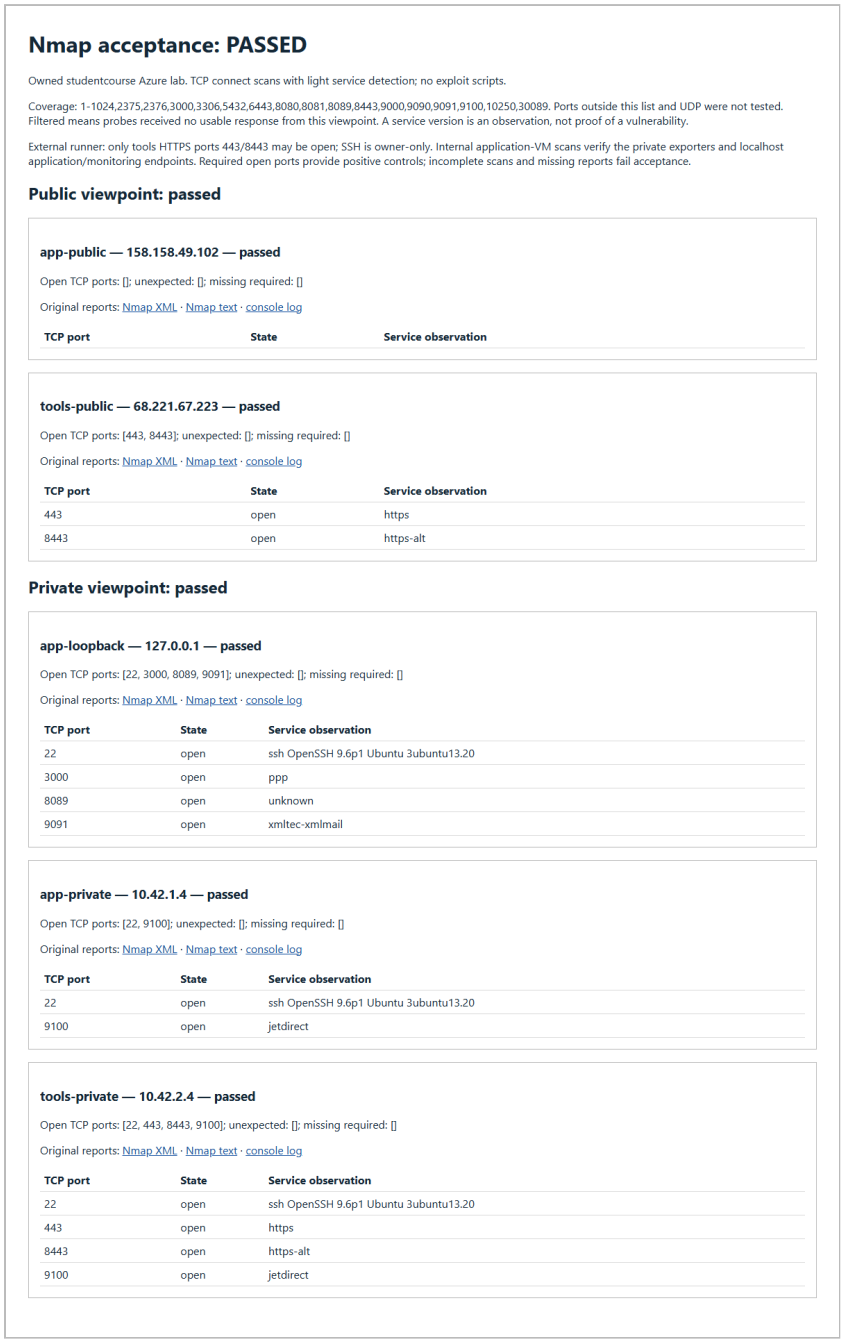
D. Acceptance

14. Network acceptance [Verified in a real run]

Technique: Scan the runner's primary IPv4 address and loopback against a TCP allowlist
Tool: Nmap

Blocks the pipeline when: Unexpected open, missing required or incomplete scans fail
Report: `acceptance/report.html`

The hosted run checks 1,041 TCP ports per target. The primary interface allows only the runner's OpenSSH listener. Loopback requires Grafana, the registry, the API and Prometheus, and also allows OpenSSH.



Nmap acceptance: PASSED

Owned studentcourse Azure lab. TCP connect scans with light service detection; no exploit scripts.

Coverage: 1-1024,2375,2376,3000,3306,5432,6443,8080,8081,8089,8443,9000,9090,9091,9100,10250,30089. Ports outside this list and UDP were not tested. Filtered means probes received no usable response from this viewpoint. A service version is an observation, not proof of a vulnerability.

External runner: only tools HTTPS ports 443/8443 may be open; SSH is owner-only. Internal application-VM scans verify the private exporters and localhost application/monitoring endpoints. Required open ports provide positive controls; incomplete scans and missing reports fail acceptance.

Public viewpoint: passed

app-public — 158.158.49.102 — passed

Open TCP ports: []; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation

tools-public — 68.221.67.223 — passed

Open TCP ports: [443, 8443]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
443	open	https
8443	open	https-alt

Private viewpoint: passed

app-loopback — 127.0.0.1 — passed

Open TCP ports: [22, 3000, 8089, 9091]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
3000	open	ppp
8089	open	unknown
9091	open	xmltec-xmlmail

app-private — 10.42.1.4 — passed

Open TCP ports: [22, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
9100	open	jetdirect

tools-private — 10.42.2.4 — passed

Open TCP ports: [22, 443, 8443, 9100]; unexpected: []; missing required: []

Original reports: Nmap XML · Nmap text · console log

TCP port	State	Service observation
22	open	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.20
443	open	https
8443	open	https-alt
9100	open	jetdirect

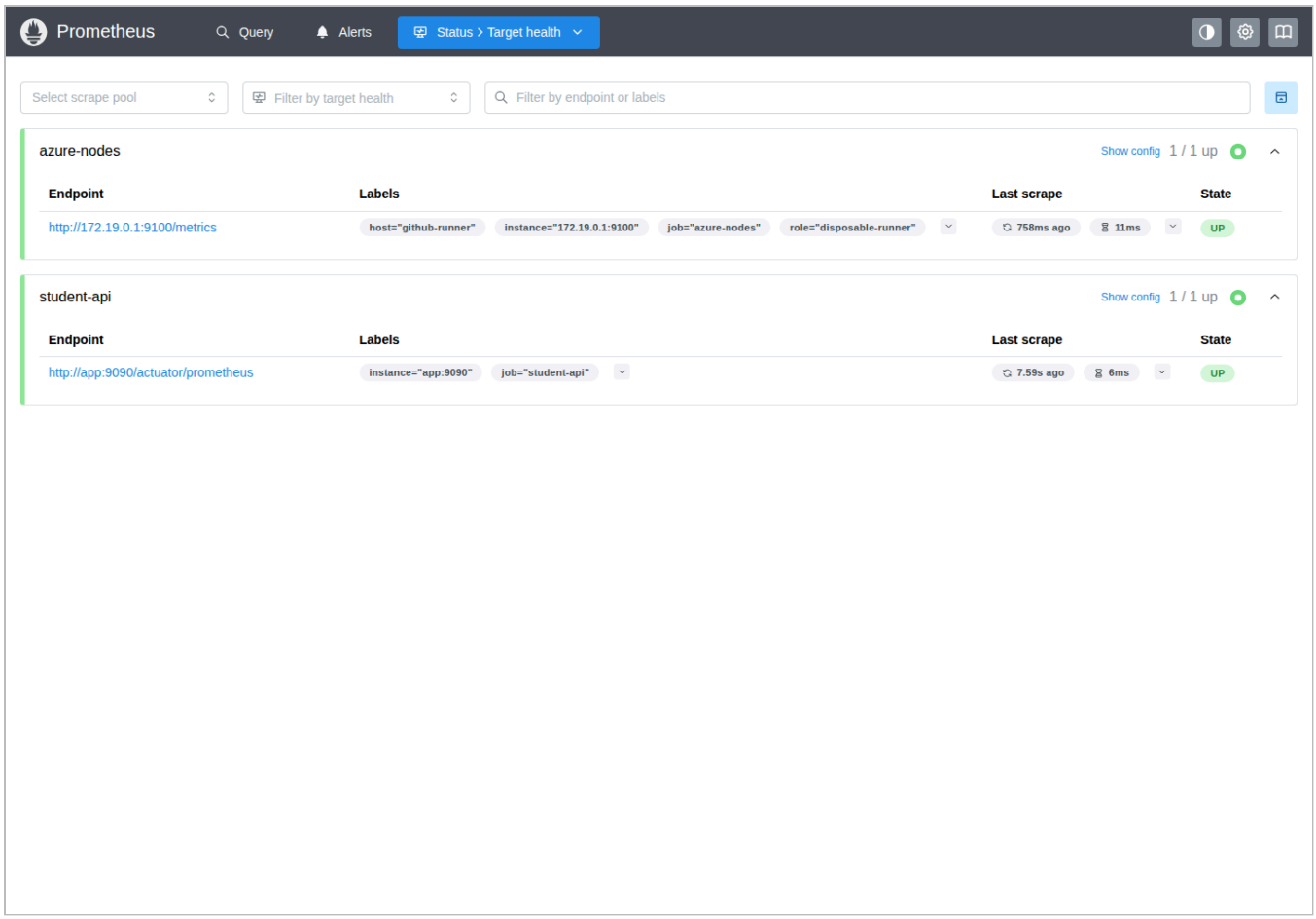
Historical Azure acceptance from public and private viewpoints (run 42016218929)

E. Production (after acceptance)

15. Monitoring: Prometheus and Grafana [Verified in a real run]

Technique: Verify scrape targets, sample real queries after light API traffic, list provisioned dashboards
Tool: Prometheus, Node Exporter, Grafana
Blocks the pipeline when: API and runner exporter UP, Grafana database healthy, both dashboards provisioned
Report: `monitoring/, prometheus/, grafana/ report.html`

The hosted run recorded both scrape targets UP and 30 successful read-only requests. The combined report includes the native metrics and the UI screenshots below.



Prometheus targets for the application and runner exporter (run 43076300738)



Grafana dashboard for the student API (run 43076300738)

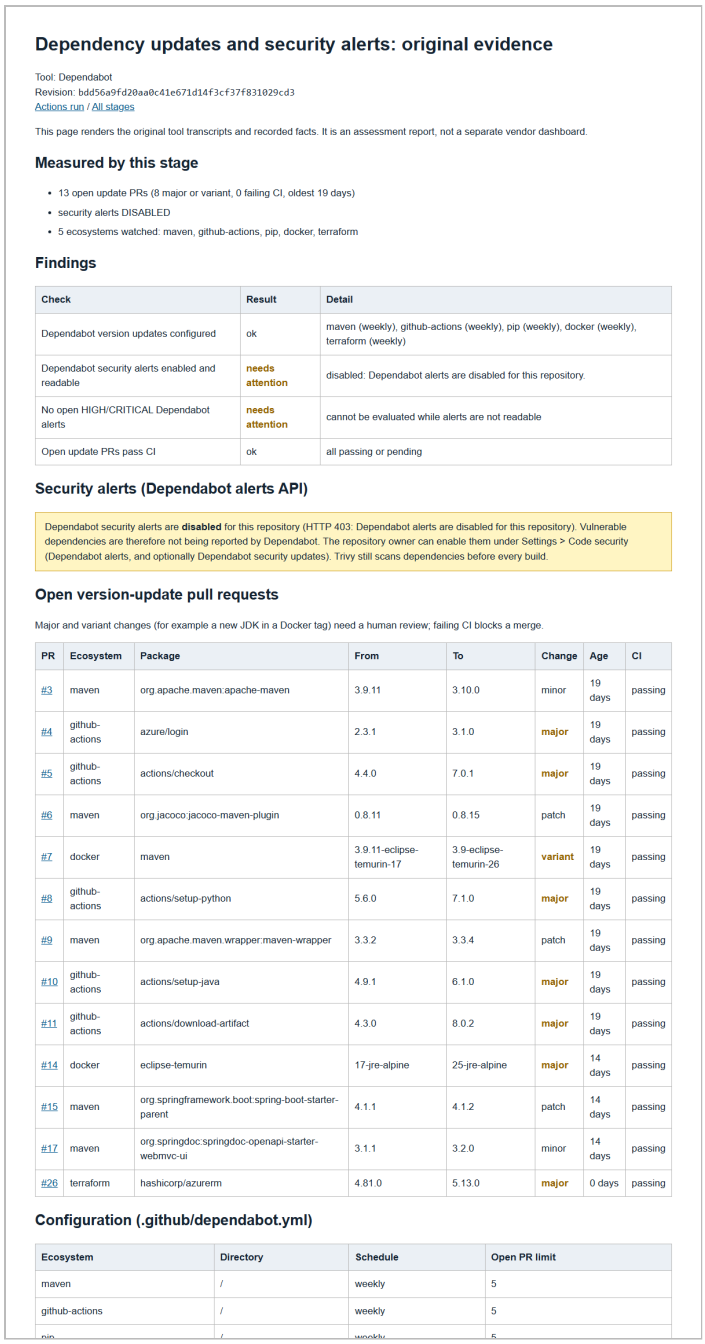


Grafana host dashboard showing the GitHub runner exporter (run 43076300738)

16. Dependency updates and security alerts [Verified in a real run]

Technique: Continuous dependency maintenance: weekly version-update PRs for five ecosystems and GitHub's vulnerability alerts, collected into a report on every push
Tool: Dependabot, GitHub REST API
Blocks the pipeline when: Reported, not blocking: disabled alerts, HIGH/CRITICAL alerts and failing update PRs are highlighted for attention
Report: `dependabot/report.html`

The first CI run found 13 open update PRs (8 major or variant changes, all passing CI, oldest 19 days) and Dependabot security alerts DISABLED on the repository (GitHub answered HTTP 403, alerts disabled). Status is attention, not passed: enabling alerts is a repository setting for the owner.



Dependency updates and security alerts: original evidence

Tool: Dependabot
Revision: `bdd56a9fd20aa0c41e671d14f3cf37f831029cd3`
Actions run / All stages

This page renders the original tool transcripts and recorded facts. It is an assessment report, not a separate vendor dashboard.

Measured by this stage

- 13 open update PRs (8 major or variant, 0 failing CI, oldest 19 days)
- security alerts DISABLED
- 5 ecosystems watched: maven, github-actions, pip, docker, terraform

Findings

Check	Result	Detail
Dependabot version updates configured	ok	maven (weekly), github-actions (weekly), pip (weekly), docker (weekly), terraform (weekly)
Dependabot security alerts enabled and readable	needs attention	disabled: Dependabot alerts are disabled for this repository.
No open HIGH/CRITICAL Dependabot alerts	needs attention	cannot be evaluated while alerts are not readable
Open update PRs pass CI	ok	all passing or pending

Security alerts (Dependabot alerts API)

Dependabot security alerts are **disabled** for this repository (HTTP 403: Dependabot alerts are disabled for this repository). Vulnerable dependencies are therefore not being reported by Dependabot. The repository owner can enable them under Settings > Code security (Dependabot alerts, and optionally Dependabot security updates). Trivy still scans dependencies before every build.

Open version-update pull requests

Major and variant changes (for example a new JDK in a Docker tag) need a human review; failing CI blocks a merge.

PR	Ecosystem	Package	From	To	Change	Age	CI
#3	maven	org.apache.maven:apache-maven	3.9.11	3.10.0	minor	19 days	passing
#4	github-actions	azure/login	2.3.1	3.1.0	major	19 days	passing
#5	github-actions	actions/checkout	4.4.0	7.0.1	major	19 days	passing
#6	maven	org.jacoco:jacoco-maven-plugin	0.8.11	0.8.15	patch	19 days	passing
#7	docker	maven	3.9.11-eclipse-temurin-17	3.9-eclipse-temurin-26	variant	19 days	passing
#8	github-actions	actions/setup-python	5.6.0	7.1.0	major	19 days	passing
#9	maven	org.apache.maven.wrapper:maven-wrapper	3.3.2	3.3.4	patch	19 days	passing
#10	github-actions	actions/setup-java	4.9.1	6.1.0	major	19 days	passing
#11	github-actions	actions/download-artifact	4.3.0	8.0.2	major	19 days	passing
#14	docker	eclipse-temurin	17-jre-alpine	25-jre-alpine	major	14 days	passing
#15	maven	org.springframework.boot:spring-boot-starter-parent	4.1.1	4.1.2	patch	14 days	passing
#17	maven	org.springdoc:springdoc-openapi-starter-webmvc-ui	3.1.1	3.2.0	minor	14 days	passing
#26	terraform	hashicorp/azurerm	4.81.0	5.13.0	major	0 days	passing

Configuration (.github/dependabot.yml)

Ecosystem	Directory	Schedule	Open PR limit
maven	/	weekly	5
github-actions	/	weekly	5
pip	/	weekly	5

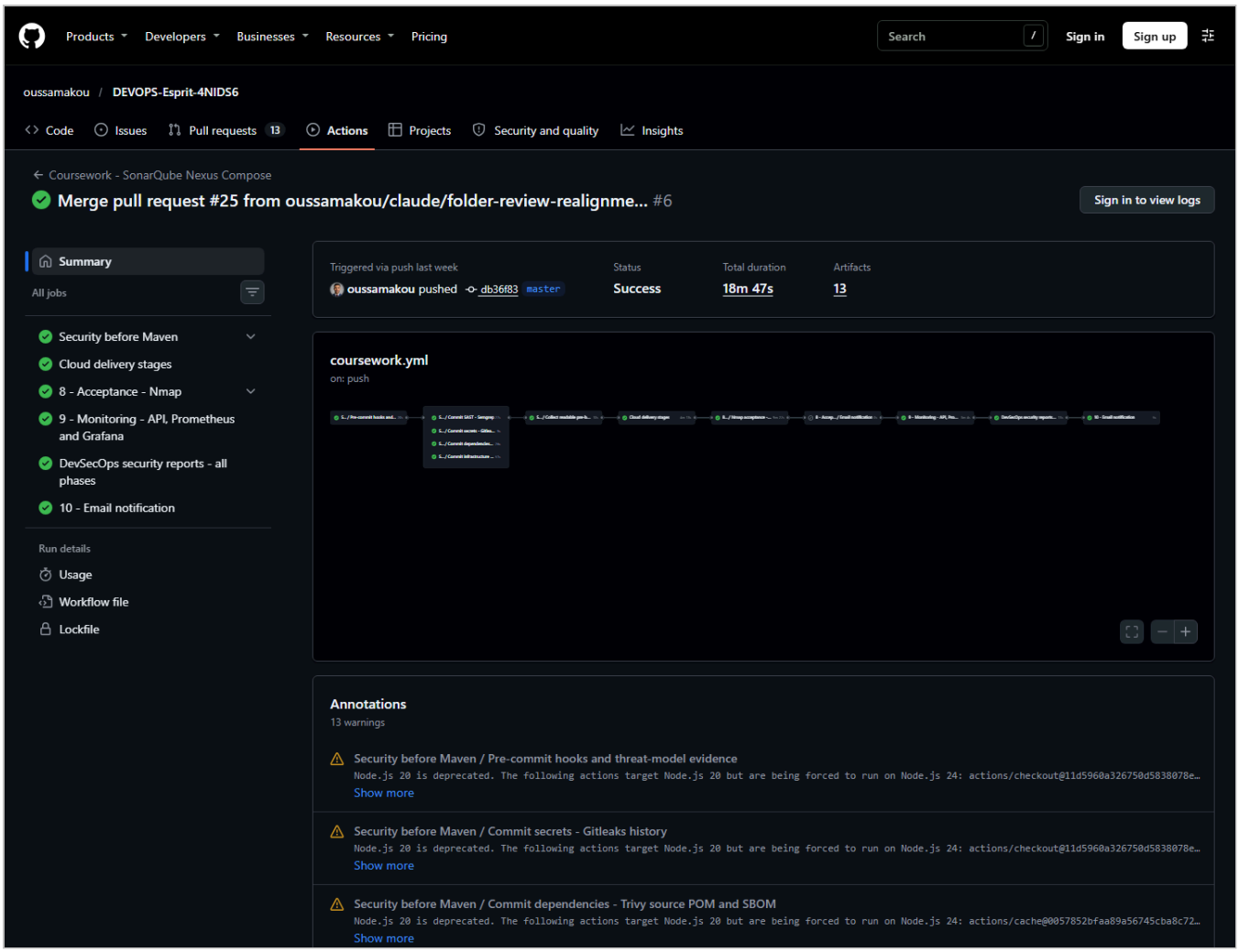
Dependabot stage page: alerts-disabled finding, 13 update PRs with major and variant changes highlighted (run 43047106961, pull request 27, 11 Nov 2026)

F. Notification

17. Email notification [Partly verified]

Technique: Status, per-stage results and the run link sent at the end of every master run
Tool: SMTP over STARTTLS
Blocks the pipeline when: Runs even after failure or cancellation
Report: `the email, and the job in the run graph`

The first hosted master run's email job succeeded and the SMTP server accepted the message. Inbox receipt remains unconfirmed.



Historical Azure run with a successful email job (run 42108525318)

Real failures found and fixed

- Trivy blocked the first image with 11 HIGH/CRITICAL findings; fixed by upgrading Spring Boot and Jackson (SECURITY-GATE-CASE-STUDY.md).
- Checkov rejected public HTTP port 80 (CKV_AZURE_160); the port was closed and the rescan passed (screenshots under Infrastructure-as-code policy).
- The first Compose deployment failed on a missing localhost port mapping and config file permissions; repaired and re-run (see Deployment).
- Nexus reported the default encryption key; replaced with a private key (see Artifact repository).
- The first hosted PR run stopped at Nmap when it detected the runner's OpenSSH listener. The runner policy now allows TCP 22 and continues to enforce loopback-only access for lab services.
- The historical Azure SonarQube baseline recorded six HIGH entity-binding findings.

Not yet proven (to capture)

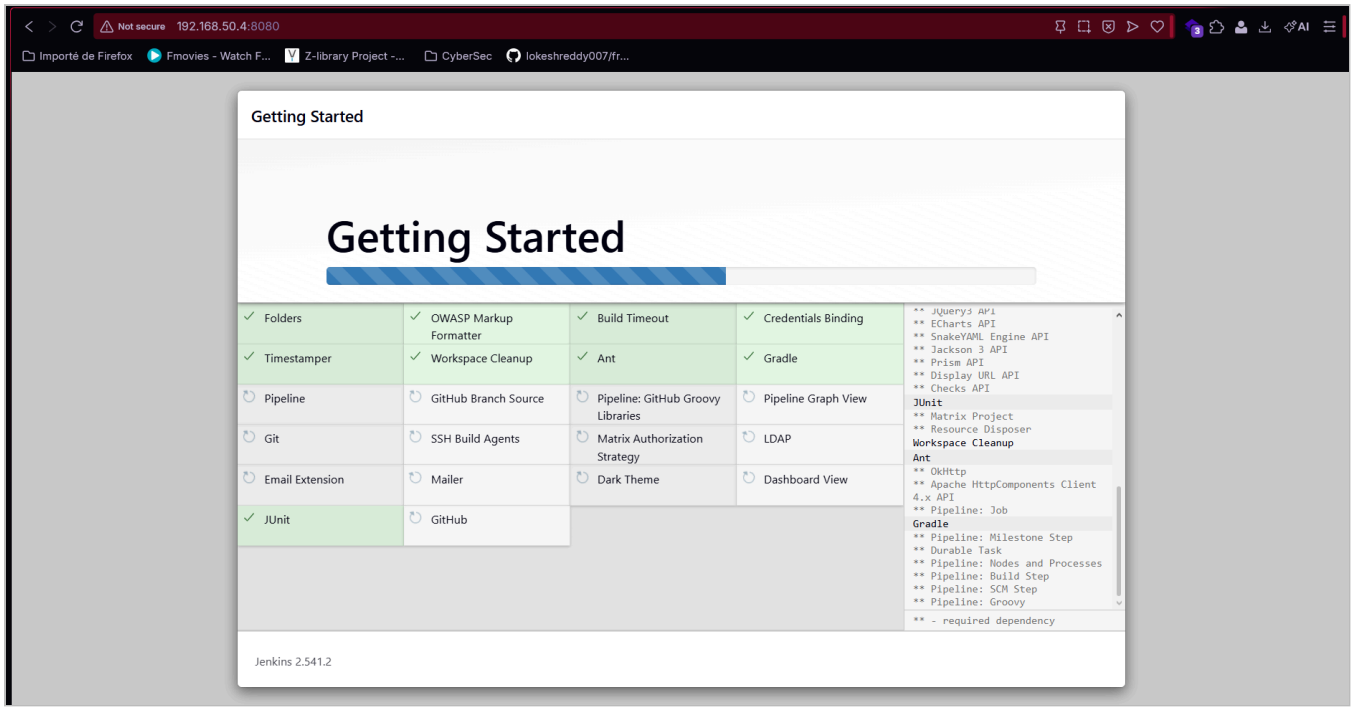
- Receipt of the first GitHub-hosted status email in the configured inbox
- Dependabot security alerts are disabled on the repository: enable them, then the report will list real alert findings

How to open the evidence

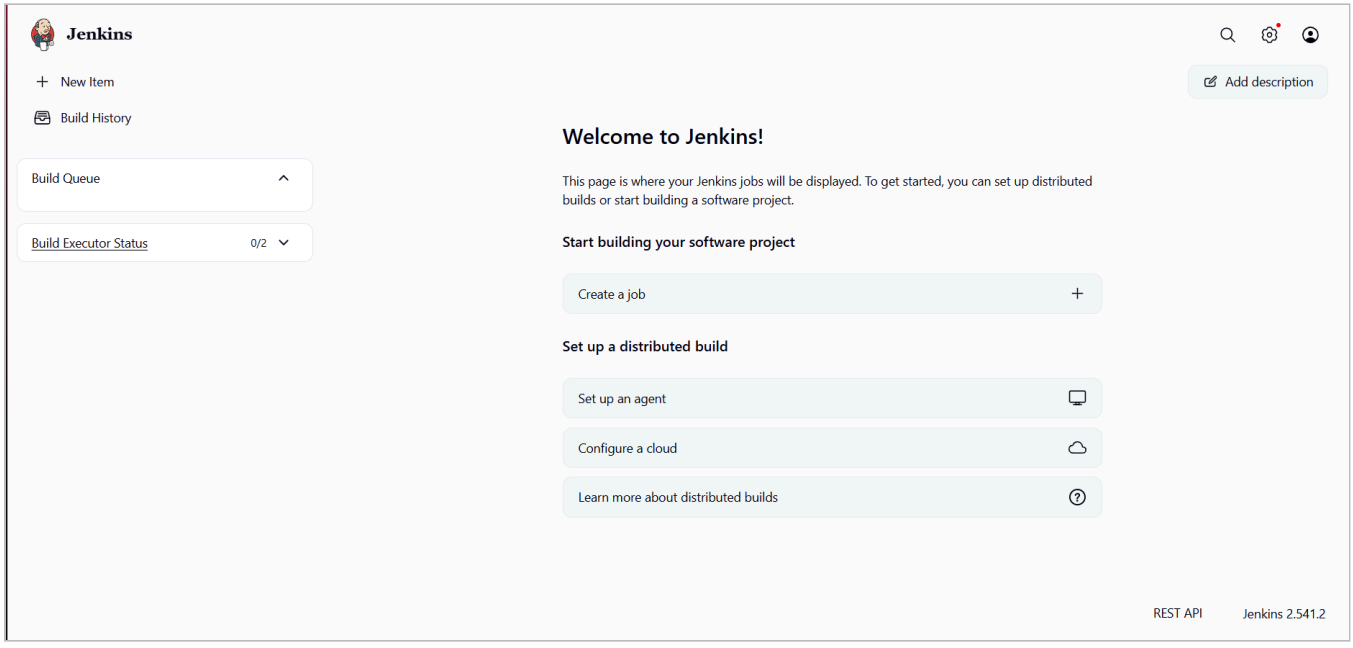
From the hosted run's artifacts, download **devsecops-security-reports**, extract it and open `index.html`. The index links to stage reports, original measurements and the screenshot gallery. The runner and its services stop after the job.

Appendix: the original Jenkins and Minikube pipeline

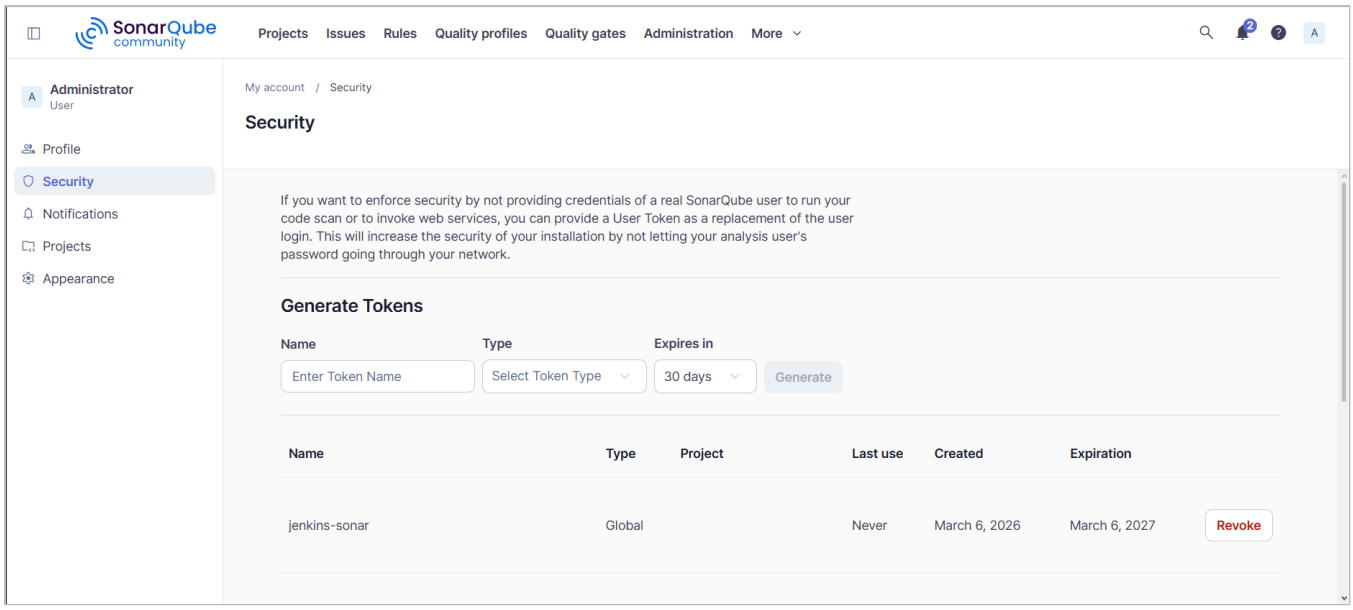
The project started with this school pipeline, preserved in documentation/LEGACY-JENKINS-MINIKUBE.md.



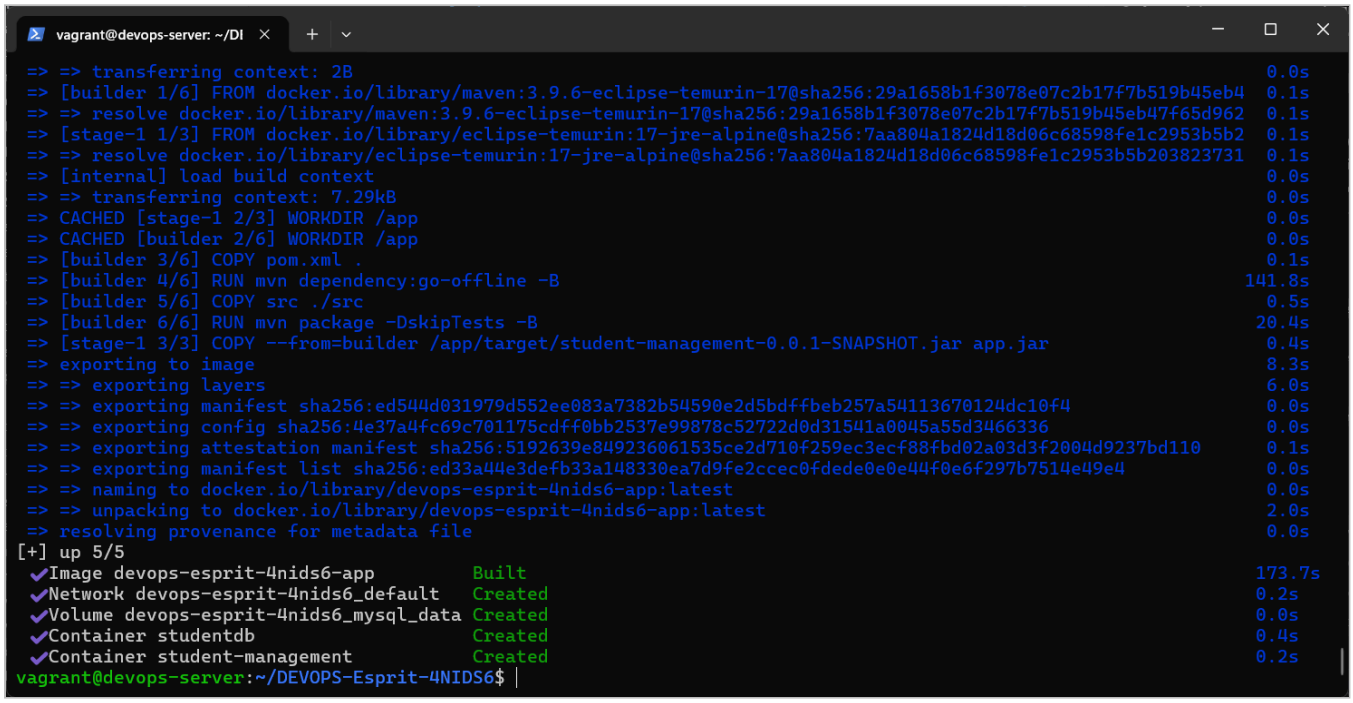
Jenkins plugin installation



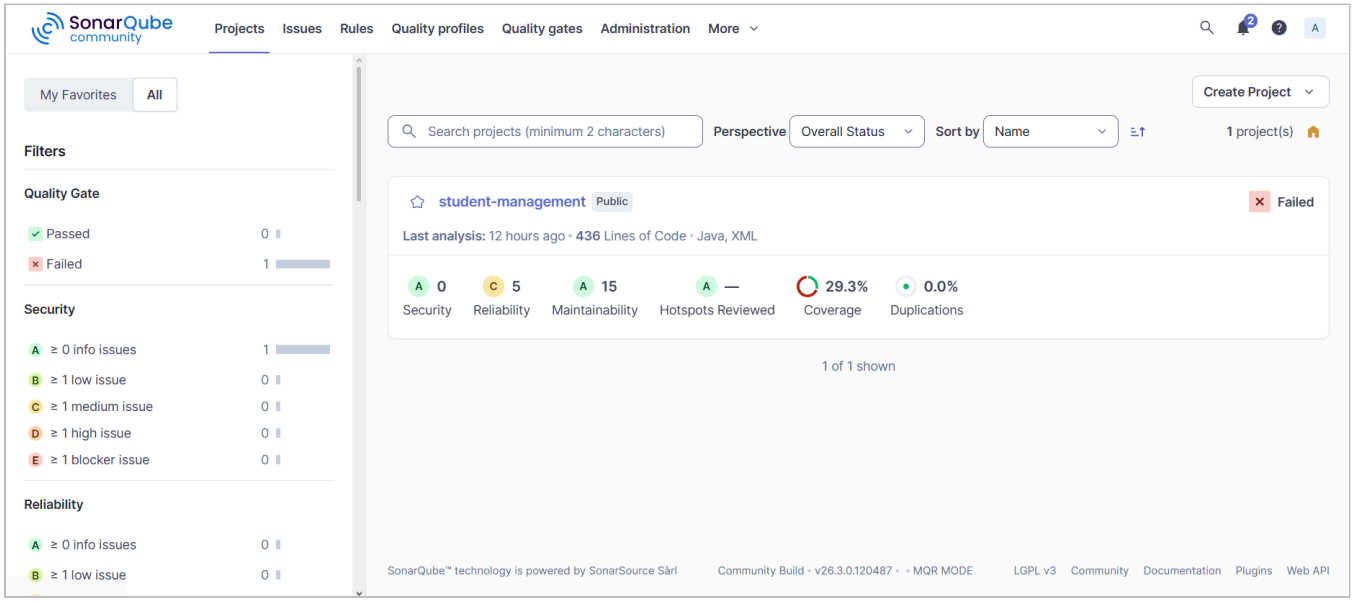
Jenkins dashboard



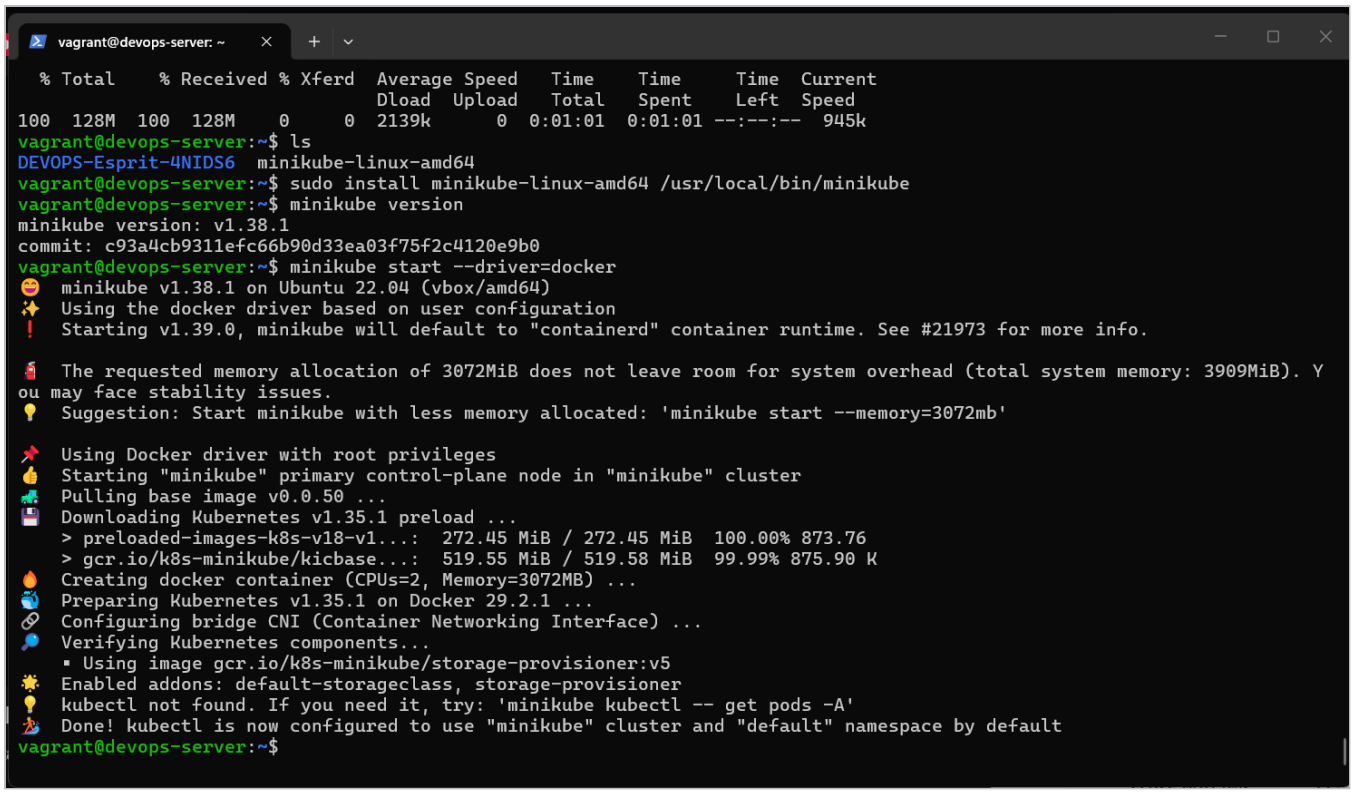
SonarQube interface



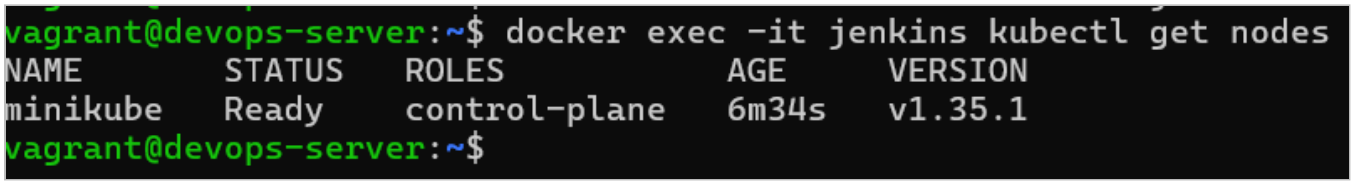
Containers running



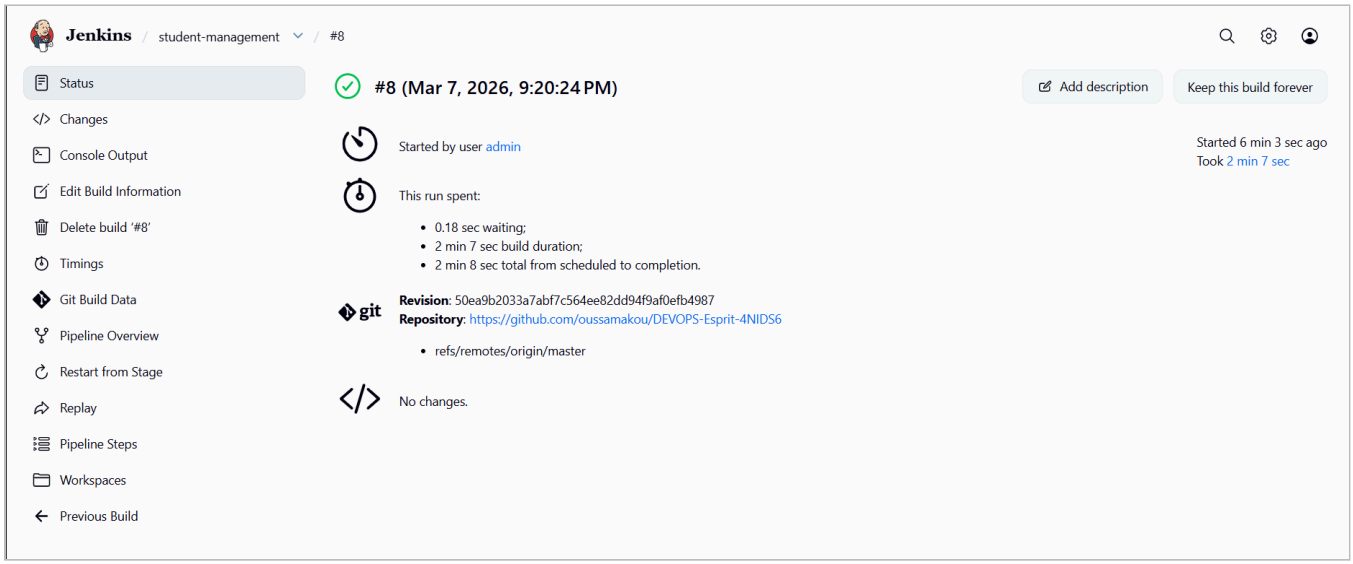
SonarQube 29% coverage



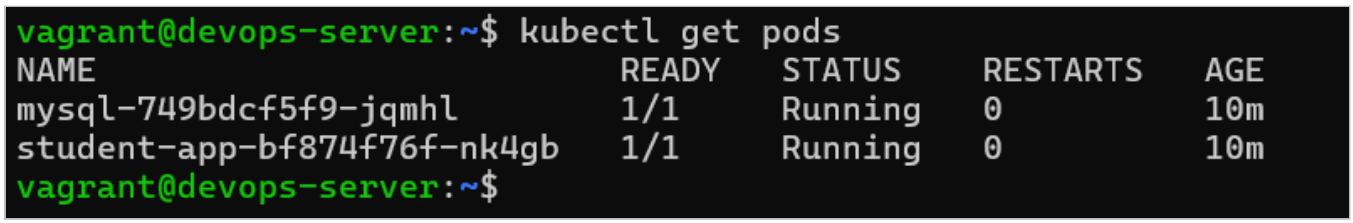
Minikube start



Minikube ready



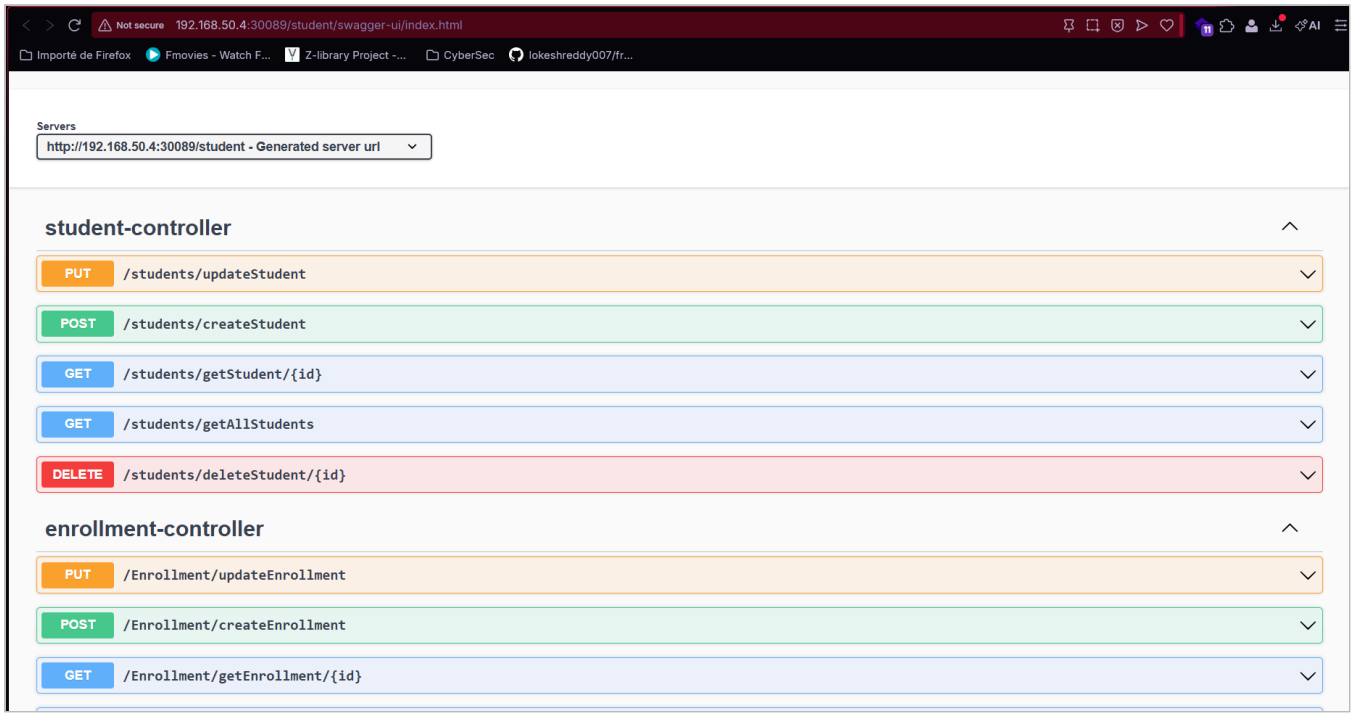
Green Jenkins pipeline



kubectl get pods

```
vagrant@devops-server:~$ kubectl get svc
NAME              TYPE        CLUSTER-IP      EXTERNAL-IP   PORT(S)          AGE
kubernetes        ClusterIP   10.96.0.1       <none>        443/TCP          23m
mysql             ClusterIP   10.107.211.25   <none>        3306/TCP         12m
student-service   NodePort    10.97.246.53    <none>        8089:30089/TCP   12m
vagrant@devops-server:~$ minikube service student-service --url
http://192.168.49.2:30089
```

kubectl get svc



Swagger UI